

Cybersecurity

Minacce e scenari d'attacco

Cybersecurity

Minacce e scenari d'attacco

Modulo I

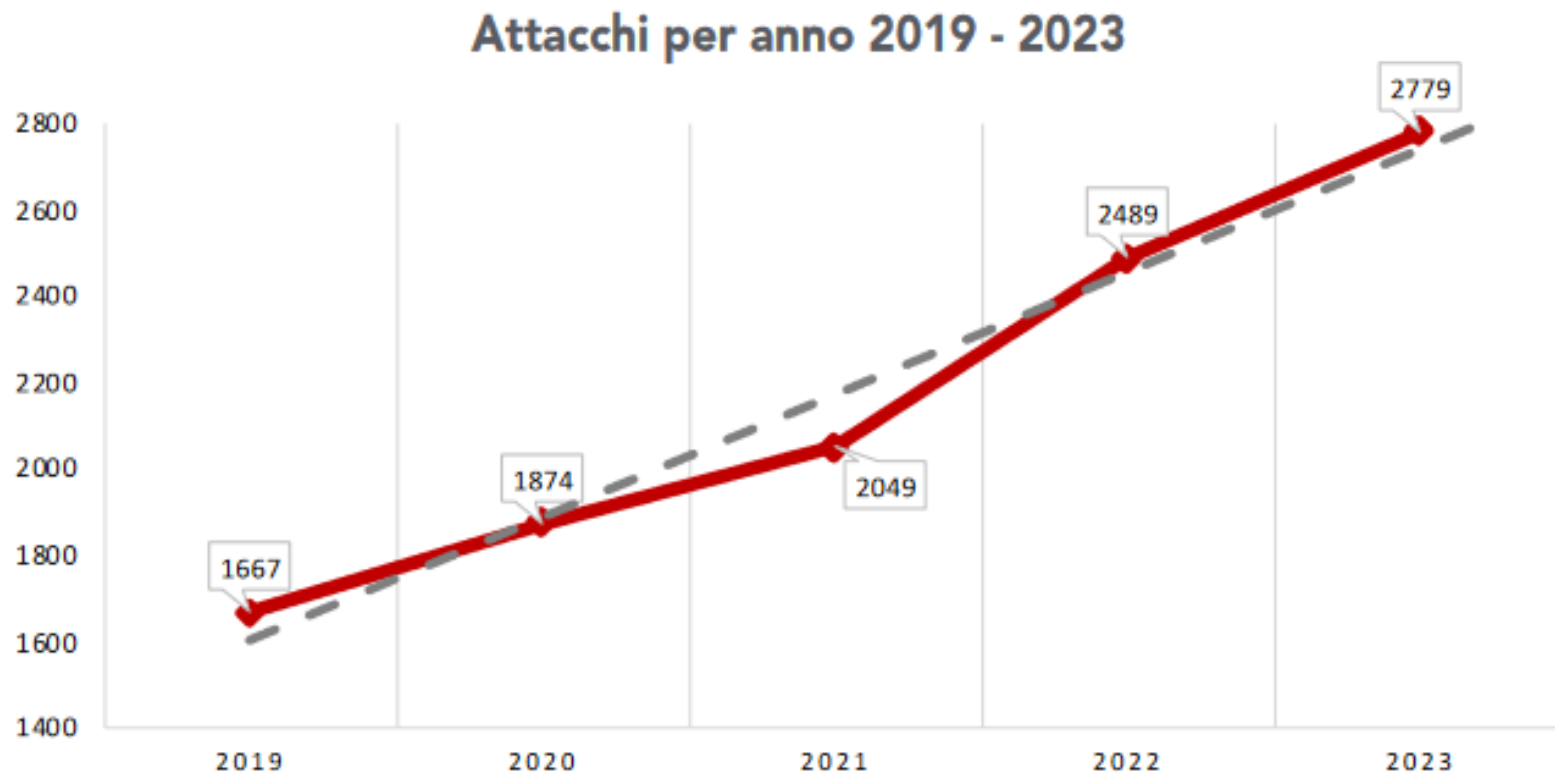
- Introduzione -

Numeri

Attacchi
Rilevanti
10858

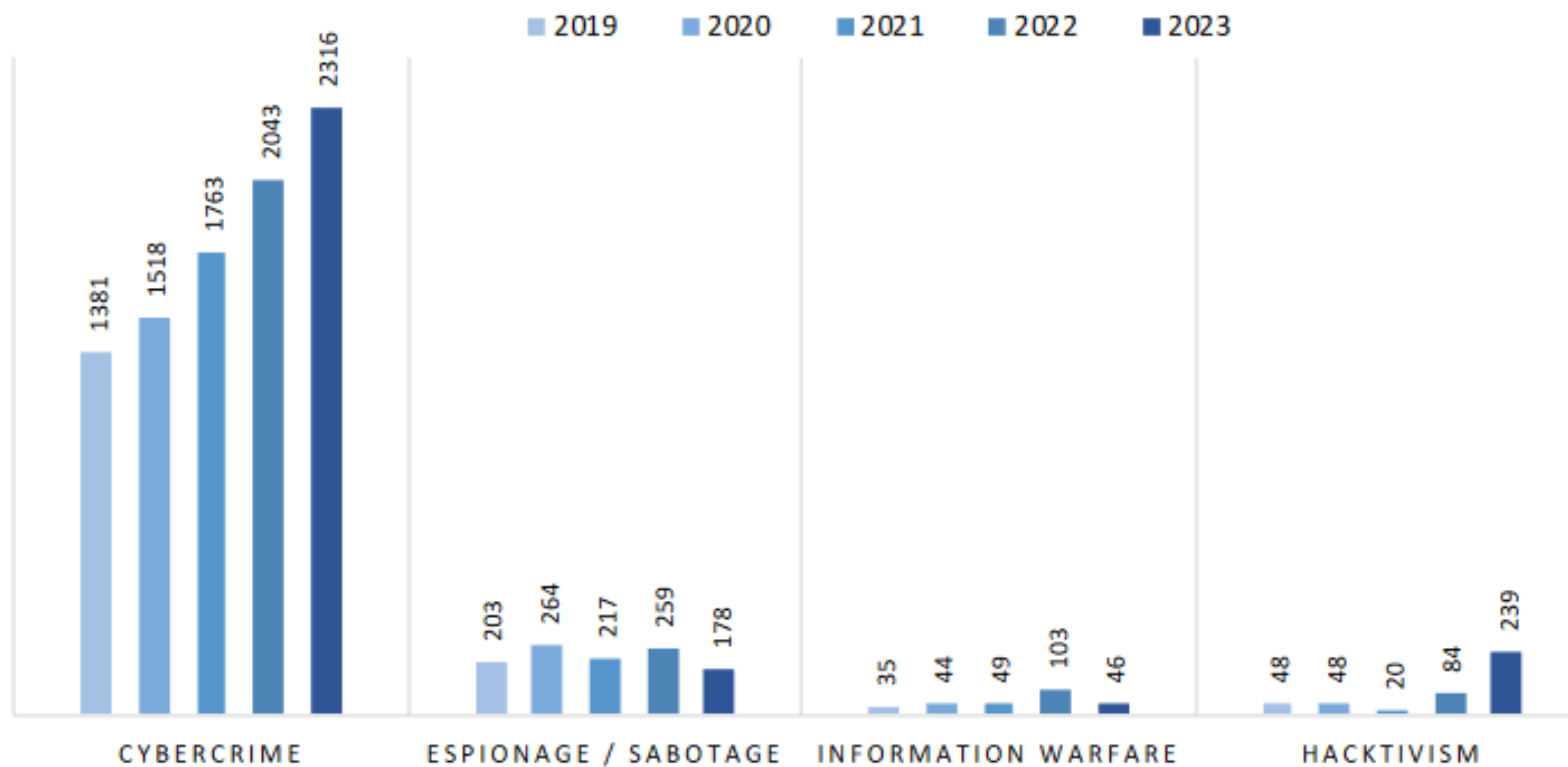
(1 gen 2019 – 31 dic 2023)

- 🕒 1667 nel 2019
- 🕒 1874 nel 2020
- 🕒 2049 nel 2021
- 🕒 2489 nel 2022
- 🕒 2779 nel 2023



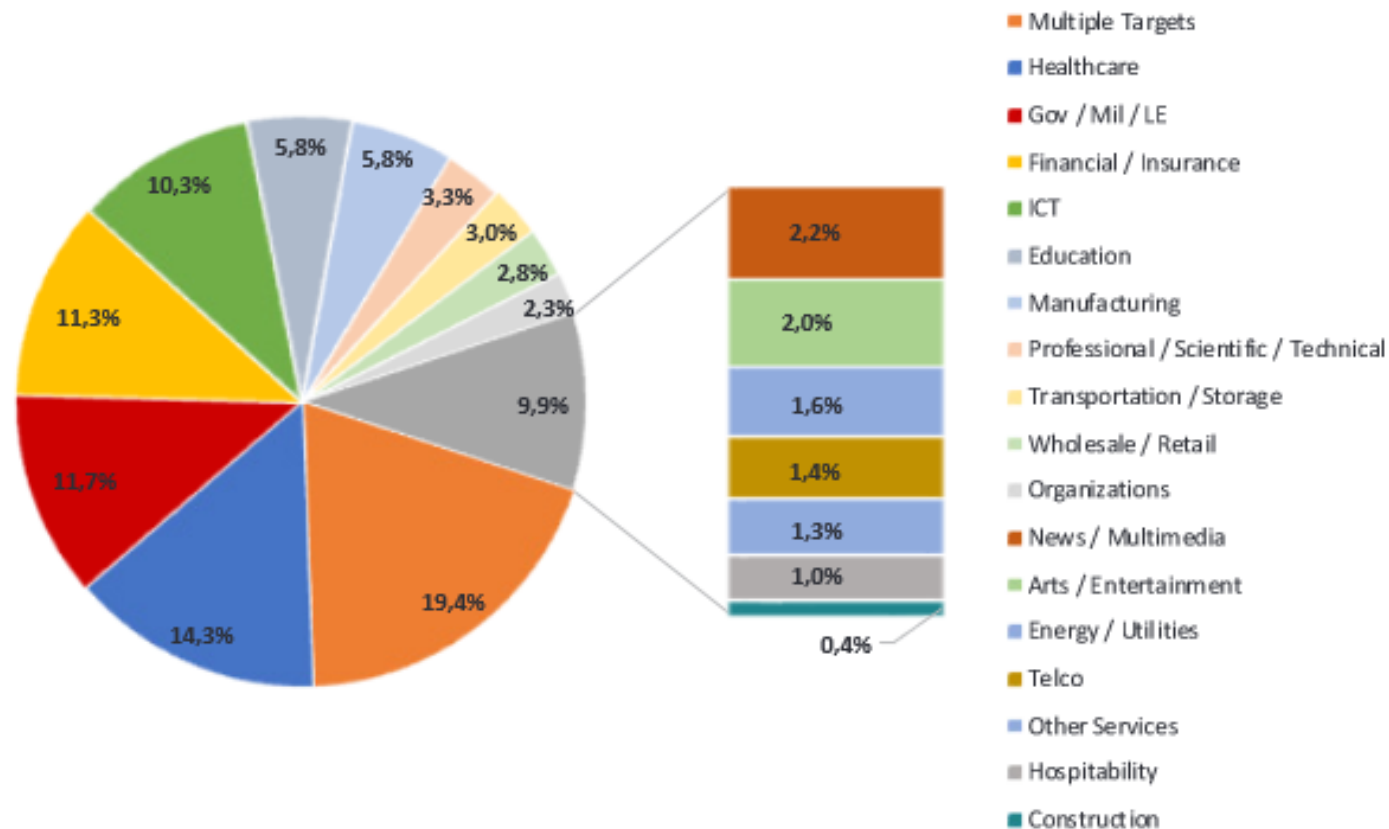
Numeri

Attaccanti 2019 - 2023



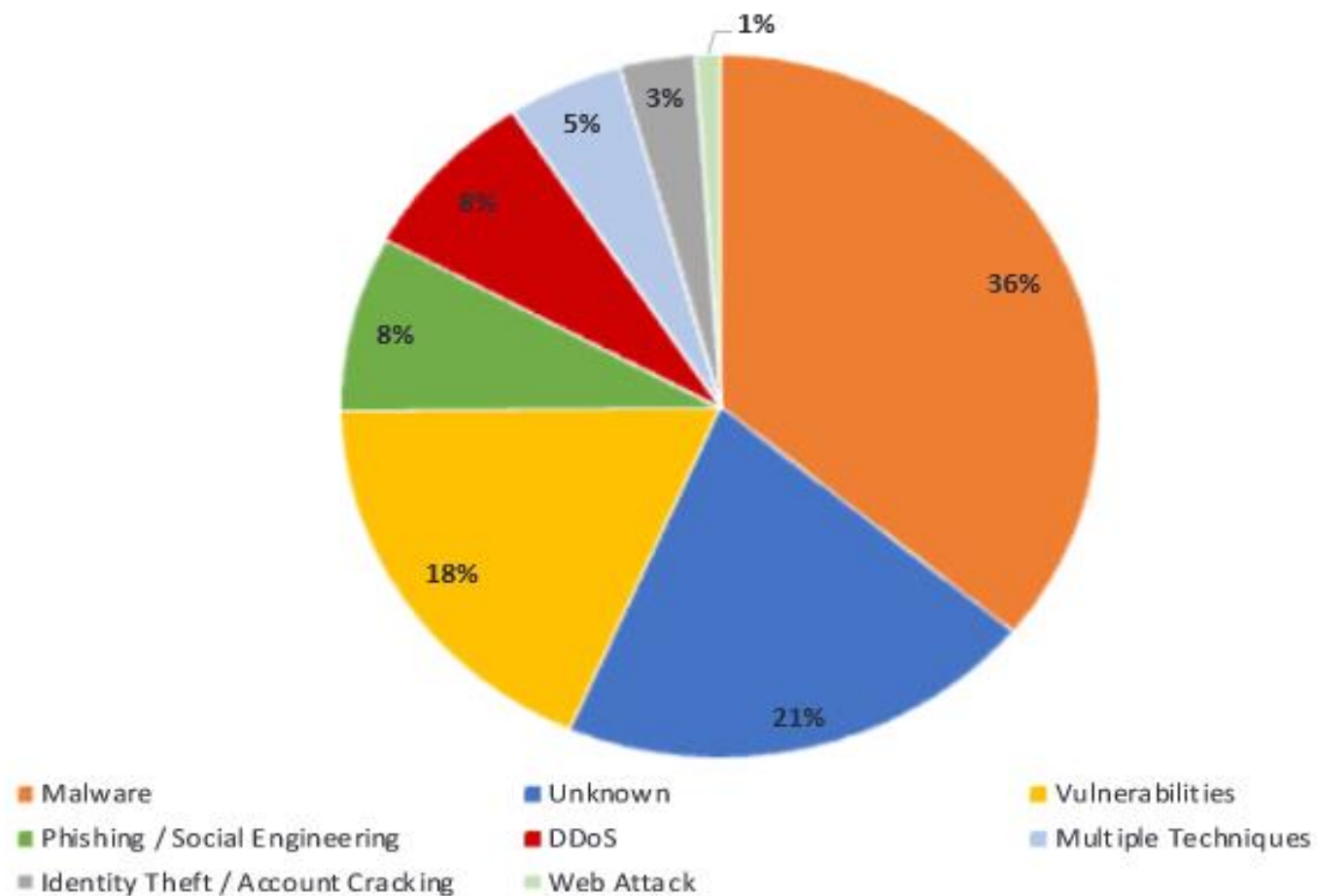
Numeri

Distribuzione delle vittime 2023



Numeri

Distribuzione delle tecniche 2023



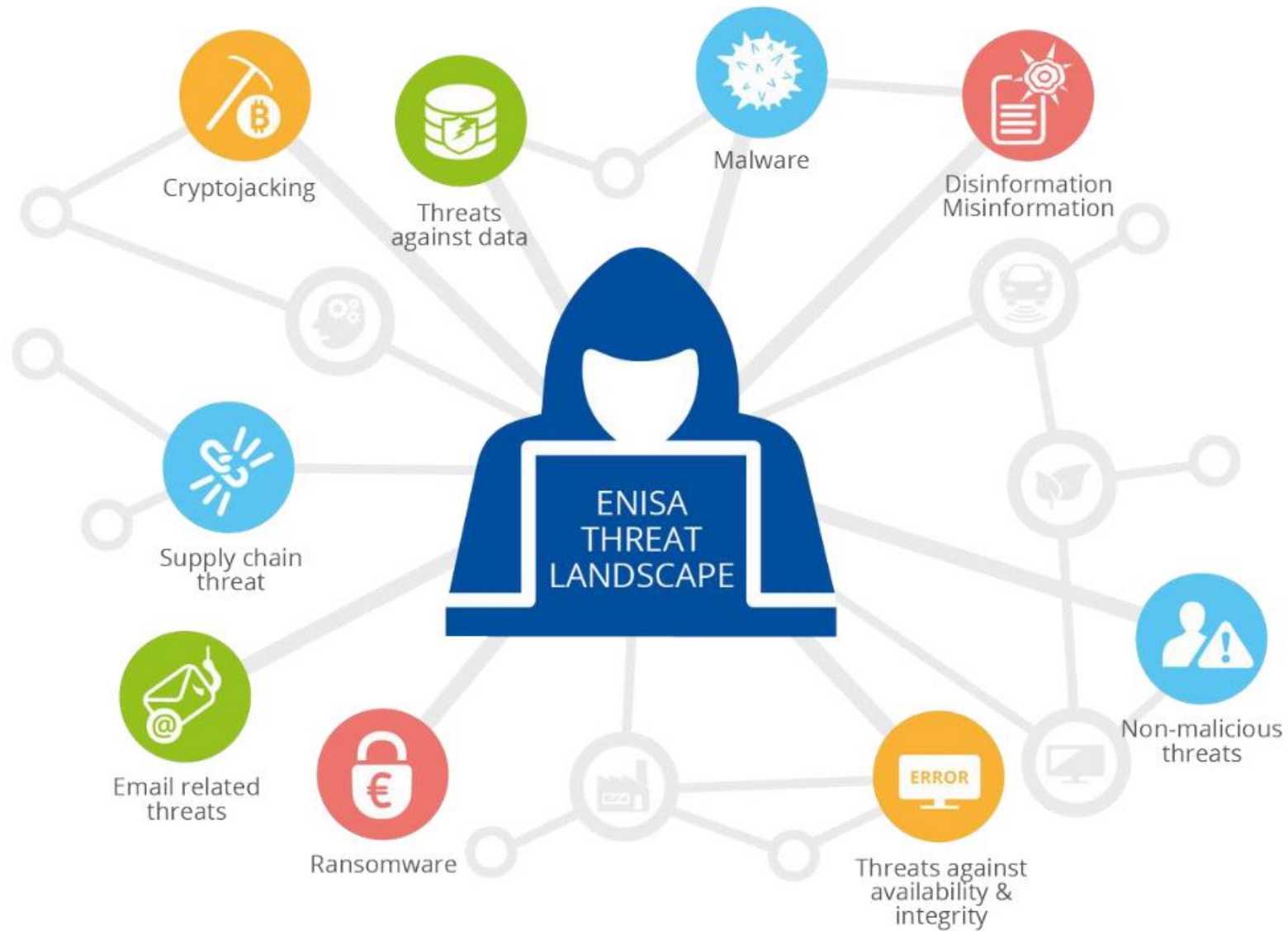
Triade CIA

Confidenzialità (Confidentiality): Regolamentare e definire chi ha accesso a quali dati o informazioni e in che misura. Per garantire la confidenzialità usano standard o policy di classificazione dei dati e/o tecniche di crittografia.

Integrità (Integrity): È la misura della validità e dell'accuratezza dei dati. I dati devono essere protetti da modifiche non autorizzate sia a riposo che in transito, L'utilizzo di hash e checksum aiuta a verificare se un'informazione è stata alterata dopo il suo utilizzo.

Disponibilità (Availability): Le informazioni devono essere accessibili dagli utenti autorizzati ogni volta che le richiedano. Di norma è espressa come il rapporto tra tempo di attività rispetto al tempo di inattività di un sistema .

Top Threats



Ransomware

Il ransomware attacca un computer e limita la capacità dell'utente di accedere ai dati del computer.

Può limitare l'accesso rallentando il computer, negando l'accesso agli utenti autorizzati o bloccando l'accesso a programmi o risorse specifici.

Molti programmi ransomware attuali funzionano crittografando file importanti o persino l'intero disco e rendendoli inaccessibili.

L'impossibilità di accedere a parti chiave di un sistema informatico di un'azienda può avere lo stesso effetto di un attacco DoS.

Ciò può costare a un'organizzazione ingenti somme di profitti persi in un lasso di tempo molto breve

Malware

Malware = **Malicious** Software

Rappresentano minacce per qualsiasi dispositivo connesso ad Internet e non solo.

Anche solo un usb drive infetto può causare la diffusione di un malware all'interno di un dispositivo.

Nessun dispositivo è immune, che sia un PC, un dispositivo mobile, un dispositivo IoT

Malware

Gli aggressori usano i malware, per:

- Rubare password
- Rubare informazioni riservate
- Eliminare informazioni dal sistema
- Crittografare dati
- Formattare i dischi rigidi

Sfortunatamente, il solo software antivirus non basta a controllare la presenza di malware, in quanto alcuni utilizzano tecniche per eludere il rilevamento

Malware

Un malware attacca tutte e tre le proprietà di sicurezza delle informazioni

Confidenzialità

Il malware può divulgare le informazioni private della tua organizzazione. Esistono forme di malware che possono recuperare le informazioni proprietarie della tua organizzazione e inviarle a destinazioni non autorizzate.

Integrità

Il malware può modificare i record del database, immediatamente o per un periodo di tempo. Nel momento si scoprono i dati modificati, si potrebbe scoprire che il malware ha corrotto anche i backup. È importante verificare l'integrità di tutti i dati in qualsiasi momento si sospetti una violazione della sicurezza.

Malware

Disponibilità

Il malware può cancellare o sovrascrivere file o causare danni considerevoli allo storage media. Alcuni tipi di malware rendono persino inutilizzabili le tue informazioni senza eliminarle o distruggendole.

Ad esempio il ransomware, solitamente, cripta le informazioni senza divulgarle o alterarle o distruggerle

Malware

Esempi di malware:

- Virus
- Rootkits (noti anche com RAT – Remote Access Tool)
- Logic Bomb
- Botnet
- Worms
- Trojan Horse
- Spyware
- Adware
- Keyloggers

Anche il ransomware è un tipo di malware, ma vista la grande diffusione è stato ritenuto opportuno evidenziarlo in una voce a parte

Cryptojacking

Il cryptojacking o (cryptomining malevolo) è un tipo di crimine informatico in cui un criminale utilizza segretamente la potenza di calcolo di una vittima per generare criptovaluta.

Con la proliferazione delle criptovalute e la loro sempre maggiore diffusione da parte del grande pubblico, è stato osservato un aumento dei corrispondenti incidenti di sicurezza informatica.

Per validare una transazione di criptovaluta bisogna risolvere un «puzzle» molto complesso, incentivo per coloro che sacrificano il tempo e la potenza di calcolo dei propri computer per mantenere la rete e creare nuove monete.

Minacce legate alla posta elettronica

Gli attacchi relativi alla posta elettronica sono un insieme di minacce che sfruttano le debolezze nella psiche umana e nelle abitudini quotidiane, piuttosto che le vulnerabilità tecniche nei sistemi informativi.

È interessante notare che, nonostante le numerose campagne di sensibilizzazione e di educazione contro questi tipi di attacchi, la minaccia persiste in misura notevole.

In particolare, sono in aumento i compromessi tra e-mail aziendali e tecniche sofisticate avanzate nell'estrazione di guadagni monetari

Esempi:

- Spam
- Phishing

Minacce ai dati

Questa categoria comprende violazioni/fughe di dati.

Una violazione o una perdita di dati è il rilascio di dati sensibili, riservati o protetti in un ambiente non affidabile.

Le violazioni dei dati possono verificarsi a seguito di un attacco informatico, un lavoro interno, una perdita involontaria o l'esposizione dei dati.

La minaccia continua ad essere elevata, poiché l'accesso ai dati è un obiettivo principale per gli aggressori per numerose ragioni

- Estorsione
- Riscatto
- Diffamazione
- Disinformazione

Minacce all'integrità e alla disponibilità

Disponibilità e integrità sono l'obiettivo di una pletora di minacce e attacchi, tra cui spiccano le famiglie di Denial of Service (DoS) e Web Attacks.

Strettamente correlato agli attacchi basati sul Web, il DDoS è una delle minacce più critiche per i sistemi IT, che prende di mira la loro disponibilità esaurendo le risorse, causando riduzioni delle prestazioni, perdita di dati e interruzioni del servizio.

La minaccia è costantemente classificata in alto nel panorama delle minacce, sia per la sua manifestazione in incidenti reali sia per il suo potenziale di impatto elevato.

Disinformazione

Le campagne di disinformazione sono in aumento, stimulate dal maggiore utilizzo delle piattaforme di social media e dei media online, nonché a seguito dell'aumento della presenza online delle persone a causa della pandemia di COVID-19.

Questo gruppo di minacce si è affacciato prepotentemente tra le più rischiose, la sua importanza nel mondo cibernetico è alta.

Le campagne di disinformazione sono spesso utilizzate negli attacchi ibridi per ridurre la percezione generale di fiducia, uno dei principali sostenitori della sicurezza informatica.

Minacce non malevoli

Le minacce sono comunemente considerate attività volontarie e dannose portate da avversari che hanno alcuni incentivi per attaccare un obiettivo specifico.

Con questa categoria, copriamo le minacce in cui l'intento dannoso non è evidente.

Questi si basano principalmente su errori umani e configurazioni errate del sistema, ma possono anche riferirsi a disastri fisici che colpiscono le infrastrutture IT.

Proprio per la loro natura, queste minacce hanno una presenza costante nel panorama delle minacce annuali e sono una delle principali preoccupazioni per le valutazioni del rischio.

Attacchi alla supply chain

La catena di approvvigionamento (**supply chain**) si riferisce all'ecosistema di processi, persone, organizzazioni e distributori coinvolti nella creazione e consegna di una soluzione o prodotto finale.

Nella cybersecurity, la supply chain coinvolge un'ampia gamma di risorse (hardware e software), storage (cloud o locale), meccanismi di distribuzione (applicazioni web, negozi online) e software di gestione

Un attacco alla catena di approvvigionamento si verifica quando gli attori delle minacce compromettono le reti aziendali utilizzando applicazioni o servizi connessi di proprietà o utilizzati da partner esterni, come i fornitori.

Attacchi alla supply chain

Le applicazioni e i servizi utilizzati dalle aziende sono stati spesso considerati affidabili e controllati dai team di sicurezza. Pertanto, hanno spesso accesso a dati interni sensibili o preziosi.

Se gli aggressori possono spostarsi lateralmente dalle app connesse della catena di approvvigionamento alla stessa rete aziendale più grande, potrebbero rubare, crittografare o distruggere dati critici e costare alle aziende milioni in costi di riparazione e danni alla reputazione.

Un attacco alla catena di approvvigionamento è una combinazione di almeno due attacchi:

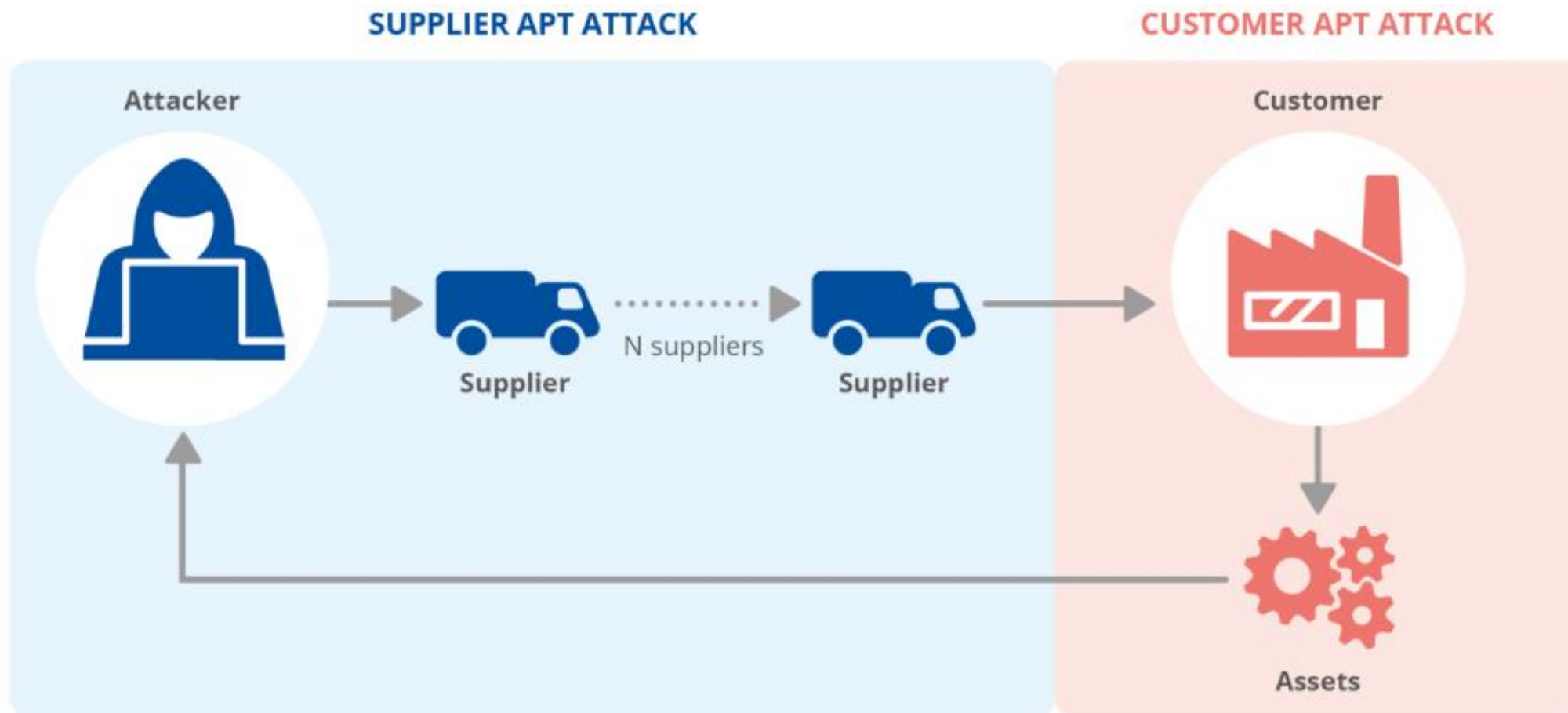
- Attacco al fornitore
- Attacco al cliente/fornitore finale

Attacchi alla supply chain

ATTACK TECHNIQUES USED TO COMPROMISE A SUPPLY CHAIN		
	Malware Infection	e.g. spyware used to steal credentials from employees.
	Social Engineering	e.g. phishing, fake applications, typo-squatting, Wi-Fi impersonation, convincing the supplier to do something.
	Brute-Force Attack	e.g. guessing an SSH password, guessing a web login.
	Exploiting Software Vulnerability	e.g. SQL injection or buffer overflow exploit in an application.
	Exploiting Configuration Vulnerability	e.g. taking advantage of a configuration problem.
	Physical Attack or Modification	e.g. modify hardware, physical intrusion.
	Open-Source Intelligence (OSINT)	e.g. search online for credentials, API keys, usernames.
	Counterfeiting	e.g. imitation of USB with malicious purposes.

Attacchi alla supply chain

Il ciclo di vita degli attacchi alla catena di approvvigionamento può essere visto come due attacchi APT intrecciati. Il primo attacco prende di mira uno o più fornitori e il secondo attacco prende di mira i clienti. Questi attacchi richiedono un'attenta pianificazione ed esecuzione.



Supply chain – Gestione del rischio dei clienti

- identificare e documentare le tipologie di fornitori e prestatori di servizi
- definire criteri di rischio per i diversi tipi di fornitori e servizi (ad es. importanti dipendenze da fornitori e clienti, dipendenze critiche da software, singoli punti di errore)
- valutare i rischi della catena di approvvigionamento in base alle proprie valutazioni e requisiti di impatto sulla continuità operative
- definire misure per il trattamento del rischio basate su buone pratiche
- monitorare i rischi e le minacce della catena di approvvigionamento, sulla base di fonti di informazione interne ed esterne e sui risultati del monitoraggio e delle revisioni delle prestazioni dei fornitori
- sensibilizzare il proprio personale al rischio

Supply chain – Gestione dei fornitori dei clienti

- gestire i fornitori durante l'intero ciclo di vita di un prodotto o servizio, comprese le procedure per gestire prodotti o componenti a fine vita
- classificare i beni e le informazioni che sono condivisi con o accessibili ai fornitori e definire le relative procedure per il loro accesso e trattamento
- definire gli obblighi dei fornitori per la protezione dei beni dell'organizzazione, per la condivisione delle informazioni, per i diritti di audit, per la continuità operativa, per lo screening del personale e per la gestione degli incidenti in termini di responsabilità, obblighi e procedure di notifica
- definire i requisiti di sicurezza per i prodotti e servizi acquisiti
- includere tutti questi obblighi e requisiti nei contratti; concordare le regole per il subappalto e il potenziale requisito a cascata
- monitorare le prestazioni del servizio ed eseguire audit di sicurezza di routine per verificare l'aderenza ai requisiti di sicurezza informatica negli accordi; ciò include la gestione di incidenti, vulnerabilità, patch, requisiti di sicurezza, ecc.
- ricevere assicurazioni da fornitori e fornitori di servizi che non sono incluse consapevolmente funzionalità nascoste o backdoor
- garantire che i requisiti normativi e legali siano presi in considerazione
- definire processi per gestire i cambiamenti negli accordi con i fornitori, ad es cambiamenti negli strumenti, nelle tecnologie, ecc.

Supply chain – Sviluppo sicuro di prodotti e servizi

- garantire che l'infrastruttura utilizzata per progettare, sviluppare, produrre e fornire prodotti, componenti e servizi segua le pratiche di sicurezza informatica
- implementare un processo di sviluppo del prodotto, manutenzione e supporto che sia coerente con i processi di sviluppo del prodotto comunemente accettati
- implementare un processo di progettazione sicuro che sia coerente con le pratiche di sicurezza comunemente accettate
- considerare l'applicabilità dei requisiti tecnici in base alla categoria del prodotto e ai rischi
- offrire Dichiarazioni di Conformità ai clienti per standard noti, ad esempio ISO/IEC 27001, IEC 62443-4-1, IEC 62443-4-2 (o specifici come CSA Cloud Controls Matrix (CCM) per i servizi cloud), e garantire e attestare, per quanto possibile, l'integrità e l'origine del software open source utilizzato all'interno di qualsiasi porzione di un prodotto
- definire obiettivi di qualità come il numero di difetti o vulnerabilità identificate esternamente o problemi di sicurezza segnalati esternamente e utilizzarli come strumento per migliorare la qualità complessiva
- mantenere dati accurati e aggiornati sull'origine del codice software o componenti e sui controlli applicati a componenti, strumenti e servizi software interni e di terze parti presenti nei processi di sviluppo del software
- eseguire verifiche periodiche per garantire che le misure di cui sopra siano rispettate.

Supply chain – Gestione vulnerabilità del fornitore

Poiché qualsiasi prodotto o servizio è costruito da o si basa su componenti e software soggetti a vulnerabilità, i fornitori dovrebbero implementare buone pratiche per la gestione delle vulnerabilità

- il monitoraggio delle vulnerabilità di sicurezza segnalate da fonti interne ed esterne che includa componenti di terze parti utilizzate
- l'analisi del rischio delle vulnerabilità utilizzando un sistema di punteggio di vulnerabilità (es. CVSS)
- politiche di manutenzione per il trattamento delle vulnerabilità identificate in base al rischio
- processi per informare i clienti
- verifica e test delle patch per garantire che i requisiti operativi, di sicurezza, legali e di sicurezza informatica siano soddisfatti e che la patch sia compatibile con componenti di terze parti non integrati
- i processi per la consegna sicura delle patch e la documentazione relativa alle patch ai clienti
- la partecipazione a un programma di divulgazione delle vulnerabilità che include un processo di segnalazione e divulgazione.

Supply chain –Principali incidenti

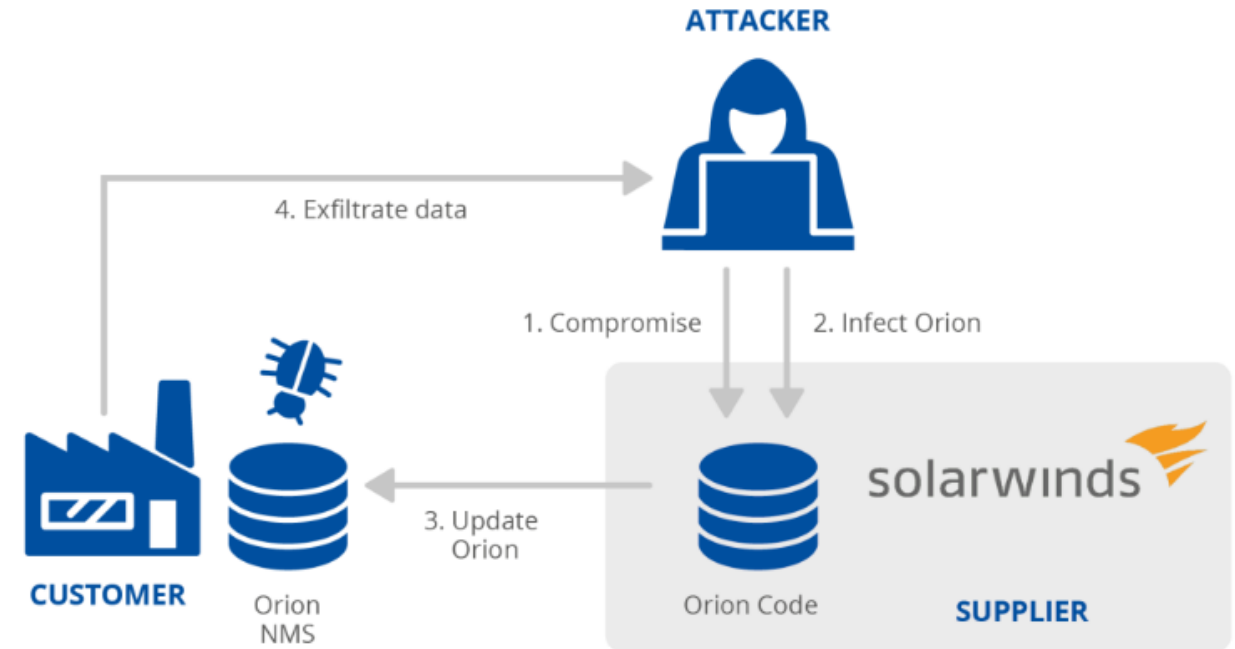
SOLARWINDS ORION: IT MANAGEMENT AND REMOTE MONITORING

SolarWinds è un'azienda che fornisce software di gestione e monitoraggio. Orion è il prodotto del sistema di gestione della rete (NMS) di SolarWinds. Nel dicembre 2020 si è scoperto che Orion era stato compromesso.

Un'indagine approfondita ha dimostrato che gli aggressori hanno ottenuto l'accesso alla rete SolarWinds, probabilmente sfruttando una **vulnerabilità zero-day** in un'applicazione o un dispositivo di terze parti, un attacco **brute-force** o attraverso l'**ingegneria sociale**. Una volta compromessi, gli aggressori hanno raccolto informazioni per un lungo periodo di tempo.

Il software dannoso è stato iniettato in Orion durante il processo di compilazione. Il software compromesso è stato quindi scaricato **direttamente dai clienti** ed è stato utilizzato per raccogliere e rubare informazioni.

L'attacco è stato attribuito al gruppo APT29.



Supply chain –Principali incidenti

Tassonomia dell'attacco a SolarWind - Orion

SUPPLIER	
Attack Techniques Used to Compromise the Supply Chain	Supplier Assets Targeted by the Supply Chain Attack
Exploiting Software Vulnerability, Brute-force attack, Social Engineering	Processes, Code

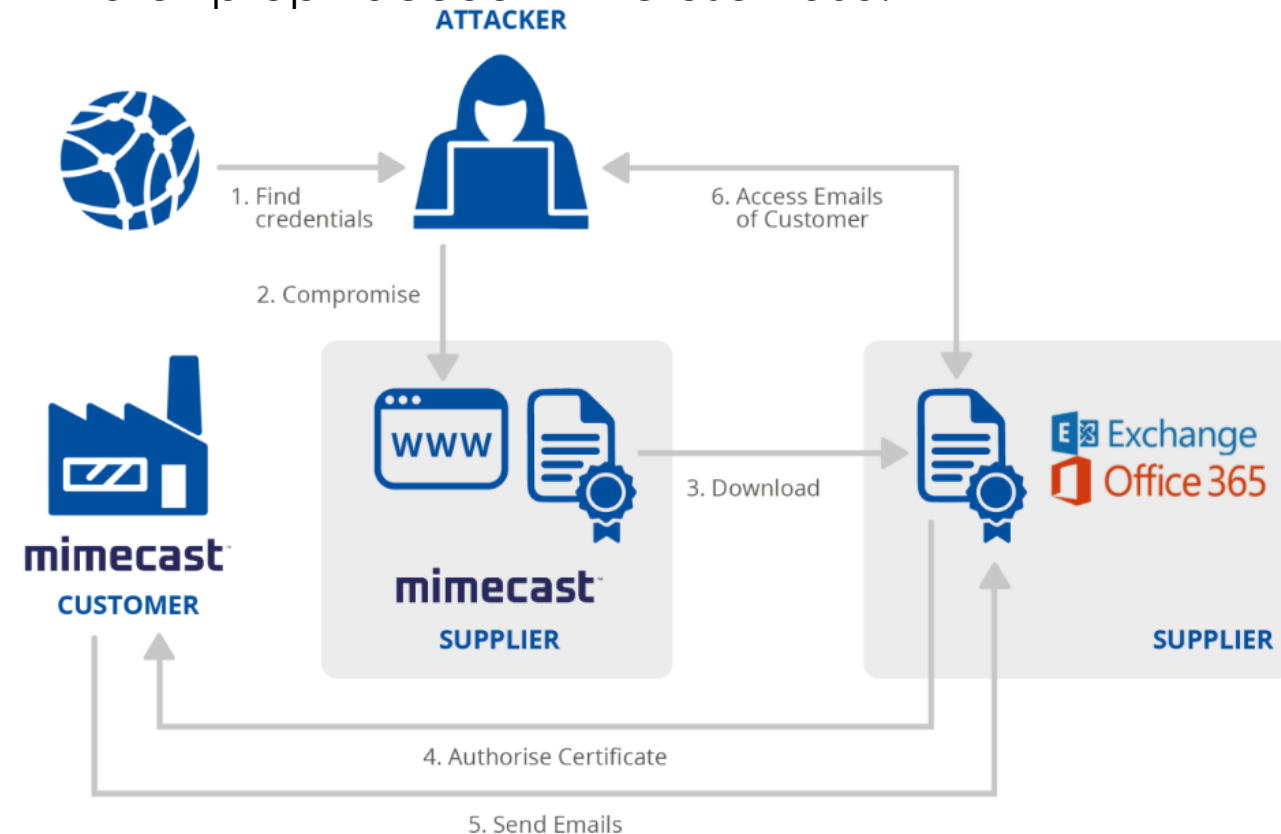
CUSTOMER	
Attack Techniques Used to Compromise the Customer	Customer Assets Targeted by the Supply Chain Attack
Trusted Relationship [T1199], Malware Infection	Data

Supply chain –Principali incidenti

MIMECAST: CLOUD CYBERSECURITY SERVICES

Mimecast è un fornitore di servizi di sicurezza informatica basati su cloud. Tra i servizi forniti, Mimecast offre servizi di sicurezza della posta elettronica, che richiedono ai clienti di connettersi in modo sicuro ai server Mimecast per utilizzare i propri account Microsoft 365.

Nel gennaio 2021, è stato scoperto che gli aggressori avevano compromesso Mimecast. Dopo la compromissione, gli aggressori hanno avuto accesso a un **certificato rilasciato da Mimecast utilizzato dai clienti** per accedere ai servizi Microsoft 365, dando loro la possibilità di **intercettare le connessioni di rete e di connettersi agli account** Microsoft 365 per rubare informazioni. L'attacco è stato attribuito al gruppo APT29. Secondo quanto riferito, il fornitore compromesso è stato collegato a SolarWinds, ma non ci sono informazioni concrete per convalidarlo.



Supply chain –Principali incidenti

Tassonomia dell'attacco a Mimecast

SUPPLIER	
Attack Techniques Used to Compromise the Supply Chain	Supplier Assets Targeted by the Supply Chain Attack
Unknown	Data

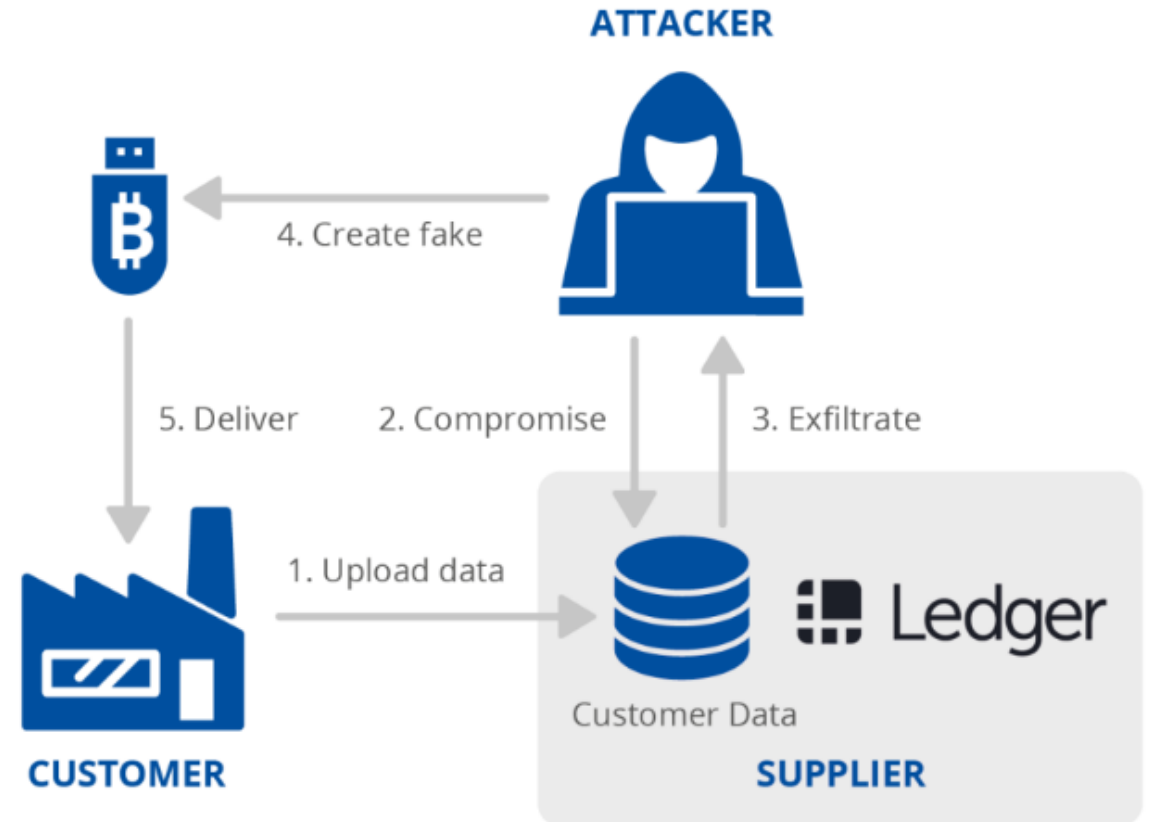
CUSTOMER	
Attack Techniques Used to Compromise the Customer	Customer Assets Targeted by the Supply Chain Attack
Trusted Relationship [T1199]	Data

Supply chain –Principali incidenti

LEDGER: HARDWARE WALLET

Ledger è un'azienda che fornisce la tecnologia del portafoglio hardware per le criptovalute.

Nel luglio 2020, gli aggressori hanno ottenuto **credenziali valide** per accedere al database di e-commerce di Ledger. I dati rubati sono stati rilasciati pubblicamente in un forum online. Gli aggressori hanno utilizzato i dati rubati per phishing online ed estorsioni di utenti e per rubare denaro agli utenti attraverso un attacco fisico dopo aver fornito agli utenti **portafogli Ledger contraffatti** che, quando collegati a un computer che richiederebbe agli utenti le loro chiavi di sicurezza, infetterebbero il computer con **malware** e rispedirebbero le informazioni rubate agli aggressori. L'attacco non è stato attribuito.



Supply chain –Principali incidenti

Tassonomia dell'attacco a Ledger

SUPPLIER	
Attack Techniques Used to Compromise the Supply Chain	Supplier Assets Targeted by the Supply Chain Attack
OSINT	Data

CUSTOMER	
Attack Techniques Used to Compromise the Customer	Customer Assets Targeted by the Supply Chain Attack
Trusted Relationship [T1199], Phishing [T1566], Counterfeiting	Financial

Altri incidenti noti

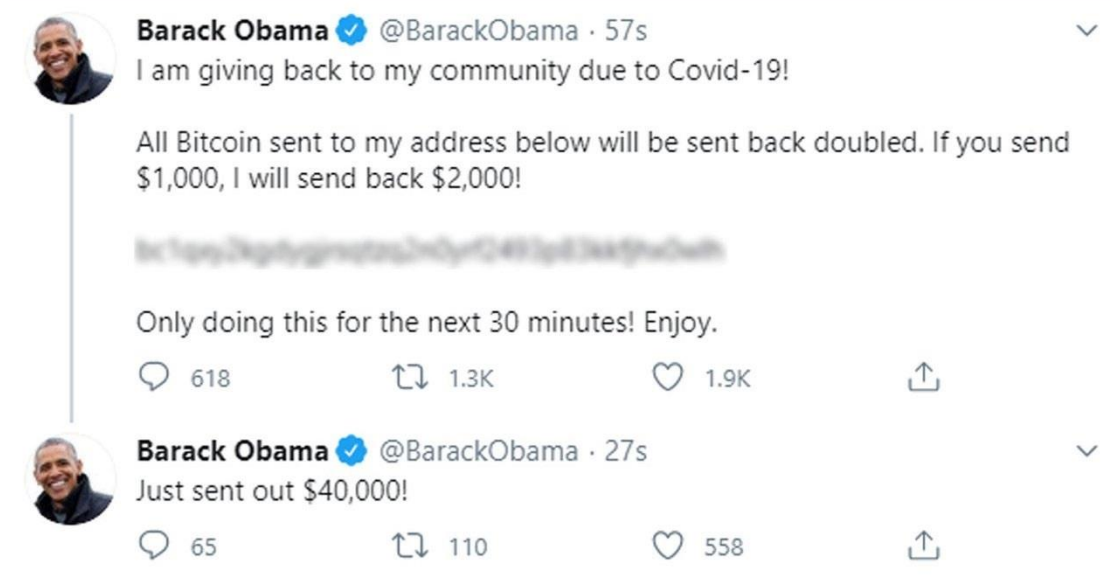
TWITTER

A luglio 2020, gli account Twitter di alcune delle persone più influenti del mondo, tra cui Barack Obama, Joe Biden, Elon Musk e Kanye West, hanno pubblicato tweet sospetti chiedendo Bitcoin.

L'hacking di Twitter è stato il culmine di uno schema di **spear-phishing** sorprendentemente elaborato che ha preso di mira i dipendenti di Twitter. L'attaccante ha **falsificato il numero di telefono di un dipendente** scambiando la SIM (ingannando un operatore telefonico nell'assegnare il numero di un'altra persona a un nuovo dispositivo).

Ha anche creato **false pagine di accesso** di Okta per i dipendenti di Twitter e ne ha persino convinto uno al telefono che era con la società I.T.

Di conseguenza, ha ottenuto con successo le **credenziali di accesso ai sistemi** sicuri di Twitter e, da lì, gli account hackerati.



Altri incidenti noti

L'hacking di Twitter è stato il culmine di uno schema di **spear-phishing** sorprendentemente elaborato che ha preso di mira i dipendenti di Twitter.

L'attaccante ha **falsificato il numero di telefono di un dipendente** scambiando la SIM (ingannando un operatore telefonico nell'assegnare il numero di un'altra persona a un nuovo dispositivo).

Ha anche creato **false pagine di accesso** di Okta per i dipendenti di Twitter e ne ha persino convinto uno al telefono che era con la società I.T.

Di conseguenza, ha ottenuto con successo le **credenziali di accesso ai sistemi** sicuri di Twitter e, da lì, gli account hackerati.

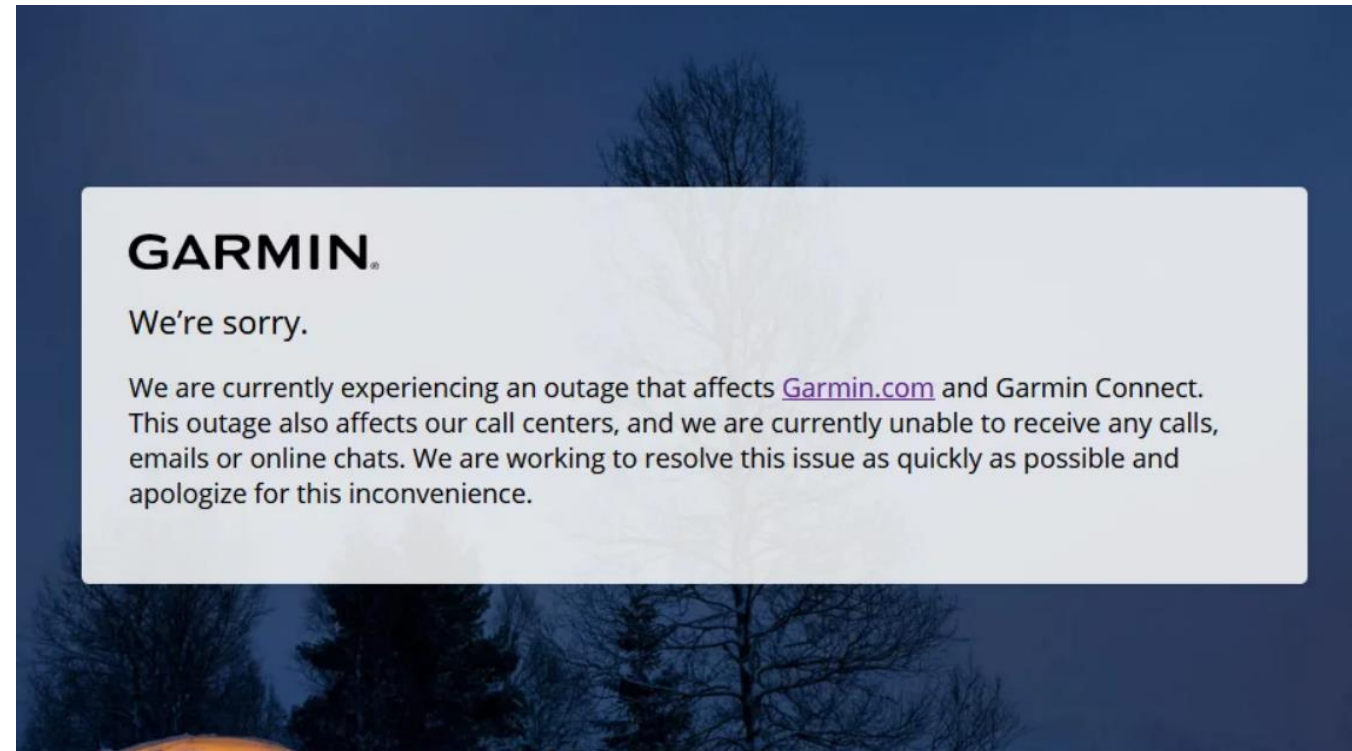
Altri incidenti noti

GARMIN

Il 23 luglio 2020, Garmin, produttore di dispositivi indossabili intelligenti, dispositivi GPS e tecnologia aeronautica, ha subito un attacco che ha causato la chiusura del suo sito Web e di alcuni dei suoi servizi.

Garmin è stato bloccato al di fuori dei propri sistemi da un **ransomware** e **ha pagato** agli aggressori milioni di dollari per la chiave di decrittazione.

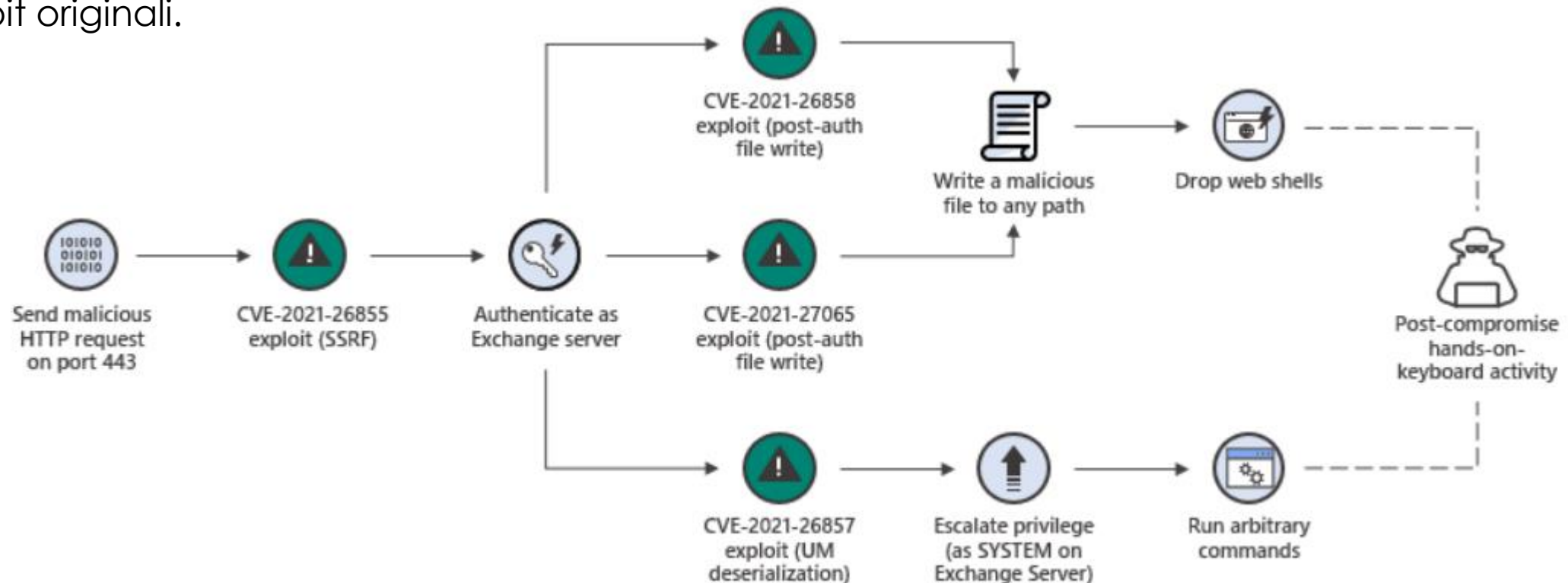
Questi hacker hanno scelto di inseguire le aree dell'attività di Garmin rivolte ai clienti, costringendoli ad agire rapidamente per ridurre al minimo le interruzioni.



Altri incidenti noti

MICROSOFT EXCHANGE

Questa violazione si è verificata quando sono stati scoperti **quattro exploit zero-day** nei server Microsoft Exchange locali, fornendo agli aggressori l'accesso completo alle e-mail e alle password degli utenti sui server interessati e ai privilegi di amministratore sul server. Gli attaccanti hanno installato una backdoor che consente di accedere ai server colpiti anche se il server viene successivamente aggiornato per non essere più vulnerabile agli exploit originali.



Altri incidenti noti

FACEBOOK

Nell'aprile 2021, il media Business Insider ha riferito che un utente in un forum di hacking ha pubblicato i dati personali di oltre 533 milioni di utenti di Facebook, contenente numeri di telefono, ID Facebook, nomi completi, luoghi, date di nascita e indirizzi e-mail.

LINKEDIN

I dati collegati a 700 milioni di utenti LinkedIn sono stati pubblicati su una piattaforma del dark web in vendita nel giugno 2021. Sfruttando l'API, gli hacker sono riusciti a fare scraping dei dati. Il tipo di dati rubati erano indirizzi e-mail, nomi completi, numeri di telefono, nomi utente di LinkedIn, esperienza personale e professionale e altri account di social media collegati.

Alcuni attacchi noti in Italia

- **Regione Lazio** (ransomware)
- **Enel** (ransomware)
- **Ransomware via falsa APP IMMUNI** (ransomware)
- **Geox** (ransomware)
- **ENAC** (ransomware)
- **Università Tor Vergata** (ransomware)
- **Luxottica** (malware)
- **Gruppo Carraro** (ransomware)
- **Comune di Rieti** (ransomware)
- **Comune di Torino** (ransomware)
- **SIAE** (ransomware)
- **Campari** (data exfiltration via malware)
- **Ho.Mobile** (data exfiltration via malware)
- **SNAI** (data exfiltration via malware)

Cybersecurity

Minacce e scenari d'attacco

Modulo II

- Evoluzione e cambiamento della sicurezza negli ultimi anni -

Evoluzione di minacce e contromisure

Anni '60: Protezione con password

Fu negli anni '60 che le organizzazioni iniziarono a diventare più protettive nei confronti dei loro computer.

Durante questo periodo, non c'era Internet o rete di cui preoccuparsi, quindi la sicurezza era in gran parte focalizzata su più misure fisiche e impedendo l'accesso a persone con sufficienti conoscenze su come utilizzare un computer.

Per fare ciò, ai dispositivi sono state aggiunte password e più livelli di protezione della sicurezza. Sono state inoltre implementate misure di sicurezza antincendio, per garantire la protezione dei dati archiviati.

Evoluzione di minacce e contromisure

Anni '70: ARPANET ,“Creeper” e “Reaper”

La sicurezza informatica è iniziata negli anni '70 quando il ricercatore Bob Thomas ha creato un programma per computer chiamato Creeper che poteva muoversi attraverso la rete di ARPANET, lasciando una scia di briciole ovunque andasse.

Ray Tomlinson, l'inventore della posta elettronica, ha scritto il programma Reaper, che ha inseguito e cancellato Creeper.

Reaper è stato il primissimo esempio di software antivirus e il primo programma autoreplicante, che lo ha reso il primo worm informatico.



Evoluzione di minacce e contromisure

Anni '80: Ampliamento di ARPANET, primi hacker, diffusione di virus e nascita dei primi antivirus

I computer iniziano a diventare sempre più connessi, i virus informatici diventano più avanzati e i sistemi di sicurezza delle informazioni non riescono a tenere il passo con la costante raffica di approcci innovativi di hacking. I russi, ad esempio, hanno iniziato a usare il cyberpower come arma e, nel 1986, hanno impiegato l'hacker tedesco Marcus Hess per rubare segreti militari statunitensi.

Evoluzione di minacce e contromisure

Il 1988 vide la nascita del Morris Worm, uno dei principali punti di svolta nella storia della sicurezza informatica. Il nome dal suo inventore Robert Morris, il worm è stato progettato per propagarsi attraverso le reti, infiltrarsi nei terminali utilizzando un bug noto e quindi copiare se stesso.

Il suo scopo era identificare le aree carenti in un sistema di prevenzione delle intrusioni di rete. Tuttavia, la sua capacità di autoreplicarsi sarebbe stata la sua rovina, poiché il worm si è replicato in modo così aggressivo da rendere inutilizzabili i computer presi di mira e rallentare Internet a un ritmo incalzante.

Si è anche diffuso rapidamente in tutta la rete e ha causato danni incalcolabili. In effetti, il danno che ha causato è stato così grave che Robert Morris è diventato la prima persona ad essere accusata con successo ai sensi del Computer Fraud and Misuse Act.

Evoluzione di minacce e contromisure

A seguito del worm Morris, è stato formato anche il Computer Emergency Response Team (CERT), al fine di prevenire che problemi informatici come questi si potessero ripetere.

Durante gli anni '80, la rete ARPANET divenne anche più comunemente nota come Internet e divenne disponibile al pubblico come Web mondiale nel 1989.

Evoluzione di minacce e contromisure

Anni '90: Diffusione di massa degli antivirus e nascita dei firewall

Con la disponibilità di Internet al pubblico, sempre più persone hanno iniziato a mettere online le proprie informazioni personali. Per questo motivo, le entità della criminalità organizzata hanno visto questa come una potenziale fonte di entrate e hanno iniziato a rubare dati a persone e governi tramite il web.

Entro la metà degli anni '90, le minacce alla sicurezza della rete erano aumentate in modo esponenziale e, pertanto, era necessario produrre firewall e programmi antivirus su base di massa per proteggere il pubblico.

Evoluzione di minacce e contromisure

È stato un ricercatore della NASA a creare il primo progetto di programma firewall, a seguito di un attacco di virus informatico nella loro base in California.

La ricerca e il loro team hanno creato un "firewall" virtuale che hanno modellato sulle strutture fisiche che impediscono la diffusione di incendi reali all'interno di edifici o strutture.

Tuttavia, mentre questi firewall e programmi antivirus sono riusciti in qualche modo a ridurre al minimo il rischio di attacchi, virus informatici e worm hanno continuato a diventare fitti e veloci, quindi gli hacker avevano sicuramente il sopravvento in quel momento.

Evoluzione di minacce e contromisure

Anni 2000: le minacce si diversificano e si moltiplicano

All'inizio degli anni 2000 le organizzazioni criminali hanno iniziato a finanziare pesantemente attacchi informatici professionali e i governi hanno iniziato a reprimere la criminalità dell'hacking, emettendo condanne molto più gravi ai colpevoli. La sicurezza delle informazioni ha continuato ad avanzare con la crescita di Internet ma, sfortunatamente, anche i virus.

Gli hacker sono diventati rapidamente in grado di creare virus che potevano colpire non solo organizzazioni specifiche, ma anche intere città, stati e persino continenti

Evoluzione di minacce e contromisure

Anni 2010: l'era delle grandi violazioni dei dati

Snowden & The NSA, 2013

Edward Snowden, un ex dipendente della CIA e appaltatore del governo degli Stati Uniti, ha copiato e divulgato informazioni riservate dalla National Security Agency (NSA), evidenziando il fatto che il governo stava effettivamente "spiando" il pubblico. È polemicamente considerato un eroe per alcuni e un traditore per altri.

Yahoo, 2013 – 2014

Gli hacker hanno fatto irruzione in Yahoo, mettendo a rischio gli account e le informazioni personali di tutti i loro tre miliardi di utenti. Sono stati multati di 35 milioni di dollari per non aver divulgato tempestivamente la notizia della violazione e, di conseguenza, il prezzo di vendita di Yahoo è diminuito di 350 milioni di dollari.

Evoluzione di minacce e contromisure

WannaCry, 2017

Più ampiamente conosciuto come il primo "ransomworm", WannaCry ha preso di mira i computer che eseguono il sistema operativo Microsoft Windows e ha richiesto il pagamento del riscatto nella criptovaluta Bitcoin. In un solo giorno, il worm ha infettato oltre 230.000 computer in 150 paesi.

Evoluzione di minacce e contromisure

Lo scenario attuale (1)

Siamo nel boom dell'interconnessione.

Computer, smartphone, tablet, IoT, ecc.. sono connessi ad Internet e alle nostre reti locali, di casa o ufficio.

La connettività non è più un problema, grazie anche alla diffusione degli hotspot pubblici in bar, ristoranti, aeroporti.

Il cloud computing ha preso il sopravvento e i nostri dati e servizi risiedono da qualche parte non chiara o non nota, senza avere consapevolezza di come sia gestita la sicurezza dei sistemi che li ospitano.

Dark Web e DarkNet proliferano di hacker che offrono i propri servizi, fino ad arrivare al ransomware-as-a-service (o più in generale malware-as-a-service)

Evoluzione di minacce e contromisure

Lo scenario attuale (2)

Riceviamo decine (almeno) di messaggi via e-mail o altri mezzi di spam o di phishing, che mirano alla raccolta di informazioni personali e sensibili.

Le applicazioni e i sistemi sono presi di mira da hacker che sfruttano vulnerabilità (che siano note o meno) per introdursi nelle reti e recuperare informazioni sensibili, sia in modo diretto che indiretto (vedi gli attacchi alla supply-chain).

Inoltre il lavoro da remoto dovuto alla pandemia da COVID-19 ha amplificato notevolmente i rischi legati all'accesso da remoto agli asset aziendali.

Evoluzione di minacce e contromisure

Di fronte a tutte queste minacce si sono diffusi, in tempi relativamente brevi, sistemi hardware e software che mirano a mitigare il rischio che un attacco informatico sia portato con successo.

Nonostante tutto si riescono sempre a trovare dei punti deboli, se non in sistemi e applicazioni di per sé, nelle persone che li utilizzano.

Per questo la consapevolezza delle problematiche di sicurezza, e l'adozione di policy, procedure e standard da parte del personale sono fondamentali nelle organizzazioni per una corretta salvaguardia dell'ambiente informatico e dei dati gestiti.

Violazione dei dati

Ognuno di noi diffonde i propri dati personali (volontariamente) in svariati modi:

- Profili social
- Banche
- Siti di e-commerce
- Registrazioni a siti web

Tutto questo fa sì che i nostri dati sono in mano a terzi che dovrebbero tutelare la nostra privacy ma a volte per vari motivi questo meccanismo si rompe e i nostri dati vengono rubati e venduti da hacker (data breach).

Violazione dei dati

Cosa costituisce una minaccia ai dati?

Fuga o sabotaggio intenzionale di dati interni	Videocamere di sorveglianza
Perdita di dati interna non intenzionale	Protezione inadeguata di cartelle e file
Messaggistica istantanea / peer-to-peer	Sicurezza del database inadeguata
E-mail e Web Mail	Furto di dati da parte di intrusi
Registri Web/Wiki	SQL Injection
Pagine Web dannose	Malware
Utilizzo improprio di SSL	Dumpster diving (ricerca nei cestini/spazzatura)
Protocollo di trasferimento file (FTP)	Phishing
Supporti rimovibili / di archiviazione	Social Engineering
Errori di classificazione di sicurezza	Furto fisico
Copia cartacea	

Protezione dei dati

Per proteggere le informazioni possiamo individuare due classi di misure di sicurezza

- Basate sulla tecnologia
- Policy e processi

Protezione dei dati

Mitigazioni basate sulla tecnologia

- ✓ Secure Content Management / Information Leak Protection
- ✓ Reputation Systems
- ✓ Thin Client / Virtual Desktop Infrastructure
- ✓ Minimizing leakage via CD or DVD
- ✓ AntiVirus / AntiSpyware / AntiPhishing
- ✓ Protective Markings
- ✓ Application Proxy Firewalls
- ✓ SSL Tunneling mitigation
- ✓ Employee Internet Management / Web Filtering
- ✓ Search Google for company documents

Protezione dei dati

Mitigazioni basate su policy e processi

- ✓ Data Classification / Taxonomy
- ✓ Value / Risk matrix for data
- ✓ Ownership standards
- ✓ Secure database models
- ✓ Acceptable methods of data exchange
- ✓ Confidentiality/NDAs
- ✓ User Education
- ✓ Secure Data Destruction

Protezione dei dati

Matrice vettori di attacco / mitigazioni

VECTOR	SCM	Reputation Systems	Thin Client	SOE	AntiVirus	Protective Markings	Application Proxy FW	SSL
Email	•	•			•		•	
FTP	•				•		•	
HTTP	•	•			•		•	
IM	•				•		•	
WebLogs	•						•	
P2P	•						•	
SSL Tunnelling							•	•
Removable media	•		•	•				
Classification error						•		
Hard copy / fax								
Photographs								
Hacker penetration							•	
Malware					•		•	
Social Engineering								
Dumpster Diving								
Phishing							•	
Physical theft								

Violazione dei dati – Attacchi noti

Una lista aggiornata delle maggiori violazioni dei dati può essere vista al seguente link:

<https://www.upguard.com/blog/biggest-data-breaches>

Ci si soffermerà su tre recenti attacchi:

- Linked In (Aprile 2021)
- Twitch (Ottobre 2021)
- Gioiellerie GRAFF (Novembre 2021)

Violazione dei dati – Attacchi noti



I dati associati a **700 milioni** di utenti di LinkedIn sono stati messi in vendita in un forum del Dark Web nel giugno 2021. Questa esposizione ha avuto un impatto sul 92% della base totale di utenti di LinkedIn di 756 milioni di utenti. I dati sono stati scaricati in due ondate, esponendo inizialmente 500 milioni di utenti, e poi un secondo dump in cui l'hacker "God User" si vantava di vendere un database di 700 milioni di utenti.

I dati violati includono:

- Indirizzi email
- Nomi completi
- Numeri di telefono
- Record di geolocalizzazione
- Nome utente LinkedIn e URL del profilo
- Esperienza personale e professionale
- Genere
- Altri account e dettagli sui social media

L'hacker ha recuperato tutti questi dati sfruttando le API esposte di LinkedIn.

I dati trapelati sono sufficienti per lanciare una miriade di attacchi informatici mirati agli utenti esposti

Violazione dei dati – Attacchi noti



L'adozioni delle API come servizi web per lo scambio di informazioni è una pratica diventata consuetudine. Rispetto ai «classici» web service SOAP l'utilizzo di informazioni strutturate in formato testuale o JSON permette la diminuzione del payload delle risposte e quindi una maggiore efficienza per la trasmissione delle informazioni.

Le problematiche di sicurezza relative ad un implementazione o configurazione errata delle API è stata così forte che ha portato OWASP a creare un progetto Top 10 dedicato.

L'elenco completo è disponibile al link <https://owasp.org/www-project-api-security/>

Misure di mitigazione del rischio:

- Validazione dell'input utente
- Prevenzione DoS
- Corretta e robusta implementazione dell'autenticazione, magari tramite scambio di certificati
- Corretta configurazione e verifica dei privilegi di accesso e dei sistemi hardware e software
- Corretta gestione degli errori

Violazione dei dati – Attacchi noti



Twitch, una società di proprietà di Amazon, ha subito una violazione di quasi tutta la sua code base. L'impatto esatto degli incidenti non è stato confermato, ma data la profondità del compromesso, ha il potenziale di avere un impatto su tutti gli utenti di Twitch.

125 GB di dati sensibili sono stati pubblicati tramite un collegamento torrent sul forum anonimo 4chan.

I dati sensibili includono:

- L'intero codice sorgente di Twitch.
- Tre anni di rapporti sui pagamenti per i creatori (compresi i creatori di alto profilo)
- Tutte le proprietà di Twitch (inclusi IGDB e CurseForge).
- Codice relativo agli SDK proprietari e ai servizi AWS interni utilizzati da Twitch.
- L'identità di un concorrente di steam inedito di Amazon Game Studios - "Vapor"
- Gli "strumenti di red teaming" interni di Twitch, utilizzati dai team di sicurezza interni per esercizi di formazione sugli attacchi informatici.

La vulnerabilità di sicurezza che ha reso possibile la violazione è stata una **modifica della configurazione del server** che ha consentito **l'accesso non autorizzato** da parte di terzi.

Violazione dei dati – Attacchi noti



Utilizzare processi verificati di change management è uno dei requisiti dettato dalla normative ISO27001 inerente alla gestione dei sistemi informativi.

Basta non seguire una procedura per creare dei danni notevoli ad un'organizzazione.

Dopo ogni modifica alle configurazioni di un sistema, causate da necessità operative, aggiornamenti di sistemi operativi o patch di sicurezza, è sempre verificare che le configurazioni siano rimaste invariate o che le modifiche non abbiano causato nuove vulnerabilità.

Vulnerability scanner (processo automatico) e penetration test (processo manuale) sono le attività che danno un riscontro immediato (o quasi) sull'impatto che può avere un cambiamento di configurazione.

Inoltre le policy aziendali dovrebbero assicurare l'implementazione delle best practices per la gestione degli accessi, ovvero:

- Autenticazione: utilizzo di tecniche robuste (ad esempio 2FA)
- Autorizzazione: corretta attribuzione dei privilegi agli utenti o ai gruppi di utenti
- Accountability: memorizzazione e monitoraggio delle attività delle utenze

Violazione dei dati – Attacchi noti

G R A F F

L'esclusiva gioielleria britannica, ha subito una violazione dei dati che ha compromesso molti dei suoi famosi clienti. Il gruppo di criminali informatici russo, Conti, è stato responsabile dell'attacco portato tramite l'esecuzione di un ransomware. I dati sono stati prima trafugati e poi criptati, chiedendo un riscatto di milioni di Sterline in criptovaluta.

Secondo quanto riferito, i file trapelati includono:

- Elenchi clienti.
- Dettagli di credito.
- Fatture e ricevute

Queste informazioni potrebbero essere ulteriormente utilizzate per:

- eseguire attacchi di phishing sempre più sofisticati per ottenere informazioni ancora più sensibili e commettere frodi.
- il ricatto e l'estorsione se dei clienti sono stati sorpresi a comprare regali per amanti segreti in affari o gioielli presi di nascosto come tangenti o semplicemente da figure controverse.

«Quest'ultimo attacco mostra chiaramente come le azioni più piccole possono avere le conseguenze più grandi.» cit. Oz Alashe, CEO di CybSafe.

Violazione dei dati – Attacchi noti

G R A F F

Attualmente si ritiene che l'attacco sia stato eseguito tramite **phishing**. Un dipendente ha fatto clic su un collegamento dannoso in un'e-mail, compromettendo i sistemi e la rete di Graff ed esponendo centinaia di file riservati dei clienti.

La **consapevolezza** delle problematiche di sicurezza dovrebbe essere sempre trasmessa ai propri dipendenti, indipendentemente dalle dimensioni dell'organizzazione.

Un piano di **informazione e formazione**, oltre che a continui **promemoria e campagne di sensibilizzazione** possono aiutare a diminuire il rischio che un dipendente faccia qualche sciocchezza.

Le principali mitigazioni che aiutano a ridurre l'impatto di un attacco ransomware sono:

- Eseguire backup dei dati seguendo una schedulazione con tempistiche strette
- Criptare i dati a riposo e in transito
- Software antivirus aggiornato e configurato per eseguire scansioni automatiche
- Utilizzare il principio del Least Privilege per tutte le utenze e utilizzare il controllo dell'account utente
- Assicurarsi che il firewall sia abilitato e configurato correttamente.
- Chiudere e monitorare le porte inutilizzate

Una lista completa contenente altre mitigazioni è disponibile al link <https://www.cyber.nj.gov/mitigation-guides/ransomware-risk-mitigation-strategies>

Accesso remoto non autorizzato

Da diversi anni la maggior parte delle aziende hanno predisposto i propri sistemi per l'accesso remoto, principalmente per compiti di amministrazione.

Negli ultimi due anni la necessità di permettere l'accesso remoto a sistemi e ad applicazioni è esplosa, a causa dell'obbligo/scelta adottate dalle aziende di permettere a tutto o gran parte del personale di lavorare da remoto.

Questo ha comportato ovviamente l'aumento del rischio per le organizzazioni (vedo il caso Regione Lazio).

Accesso remoto non autorizzato

L'ambiente di lavoro remoto è particolarmente interessante per gli aggressori per diversi motivi.

- L'ambiente di rete domestica non è gestito in modo professionale. Soprattutto, ciò significa che molti più sistemi sulle reti domestiche non vengono aggiornati regolarmente e alcuni di essi non sono aggiornati rispetto alla mitigazione della vulnerabilità. Alcuni possono persino essere trattati dai loro produttori come prodotti a fine vita (EOL) e non riceveranno mai mitigazioni anche quando vengono rilevate gravi vulnerabilità.
- Per persistere su una rete aziendale, un utente malintenzionato che ha sfruttato un sistema deve evitare il rilevamento e resistere alla riparazione. Anche qui la rete domestica è più amichevole con l'attaccante; il rilevamento delle minacce è in genere quasi assente e la riparazione è accidentale, ad esempio quando un PC viene reinstallato o ritirato perché funziona lentamente.

Accesso remoto non autorizzato

L'ambiente di lavoro remoto è particolarmente interessante per gli aggressori per diversi motivi.

- L'ambiente di rete domestica non è gestito in modo professionale. Soprattutto, ciò significa che molti più sistemi sulle reti domestiche non vengono aggiornati regolarmente e alcuni di essi non sono aggiornati rispetto alla mitigazione della vulnerabilità. Alcuni possono persino essere trattati dai loro produttori come prodotti a fine vita (EOL) e non riceveranno mai mitigazioni anche quando vengono rilevate gravi vulnerabilità.
- Per persistere su una rete aziendale, un utente malintenzionato che ha sfruttato un sistema deve evitare il rilevamento e resistere alla riparazione. Anche qui la rete domestica è più amichevole con l'attaccante; il rilevamento delle minacce è in genere quasi assente e la riparazione è accidentale, ad esempio quando un PC viene reinstallato o ritirato perché funziona lentamente.

VPN

Una delle soluzioni più antiche e familiari al problema del lavoro a distanza è la rete privata virtuale, o **VPN**.

Una VPN stabilisce un tunnel crittografato tra il sistema che esegue il client VPN e un server VPN che quindi inoltra il traffico attraverso il tunnel al resto della rete aziendale. Il sistema che esegue il client VPN diventa, di fatto, un'estensione della rete aziendale, esistente all'interno del perimetro di tale rete con accesso a risorse generalmente equivalenti a qualsiasi altro sistema sulla rete aziendale.

Diversi prodotti SSL VPN **contengono vulnerabilità** che consentono a un utente malintenzionato di recuperare dati arbitrari come i file di autenticazione.

Un intruso può connettersi alla VPN e modificare le impostazioni di configurazione o connettersi a un'altra infrastruttura interna con le credenziali rubate.

Vulnerabilità e attacchi alla VPN consentono agli avversari di sovrascrivere dati, eseguire codici o comandi dannosi, causare una condizione DoS e altro ancora.

VPN

Molte organizzazioni oggi utilizzano reti private virtuali (VPN) di protezione IP (IPsec) per connettere postazioni remote. Le informazioni critiche che passano attraverso reti sconosciute sono protette dalla crittografia. È fondamentale che queste VPN utilizzino una crittografia avanzata per proteggere questo traffico e garantire la riservatezza dei dati.

VPN – Attacchi noti

Per tutto il 2020, APT29 ha preso di mira varie organizzazioni coinvolte nello sviluppo del vaccino COVID-19 in Canada, negli Stati Uniti e nel Regno Unito, molto probabilmente con l'intenzione di rubare informazioni e proprietà intellettuale relative allo sviluppo e sperimentazione di vaccini COVID-19.

APT29 utilizza malware personalizzato noto come "WellMess" e "WellMail" per prendere di mira un certo numero di organizzazioni a livello globale.

Il gruppo ha avuto successo utilizzando exploit pubblicati di recente per ottenere punti d'appoggio iniziali grazie ad alcune vulnerabilità presenti nei software di accesso remoto quali VPN e Citrix.

Il gruppo utilizza anche lo spear-phishing per ottenere le credenziali di autenticazione per le pagine di accesso accessibili da Internet per le organizzazioni target

VPN – Mitigazioni

- Ridurre la superficie di attacco del gateway VPN
- Verificare che gli algoritmi crittografici siano conformi alle policy di sicurezza internazionali e di settore
- Evitare di utilizzare le impostazioni VPN predefinite
- Rimuovere suite di crittografia inutilizzate o non conformi
- Applicare gli aggiornamenti forniti dal fornitore (ad es. patch) per gateway e client VPN in modo tempestivo
- Per le modifiche non autorizzate, cercare tutte le opzioni di configurazione. Ciò include il file chiave autorizzato di SSH, nuove regole e comandi per l'esecuzione di IPtables sui client.
- Controllare e monitorare i log VPN e il traffico di rete. Verificare le connessioni da indirizzi IP insoliti, in particolare quelli restituiti con connessioni riuscite o ampie dimensioni di dati.
- Abilitare 2FA (autenticazione a due fattori) per la VPN per proteggersi dagli attacchi di ripetizione della password nell'autenticazione a due fattori.
- Disabilita tutte le funzionalità e le porte sulla VPN che non sono richieste o utilizzate.

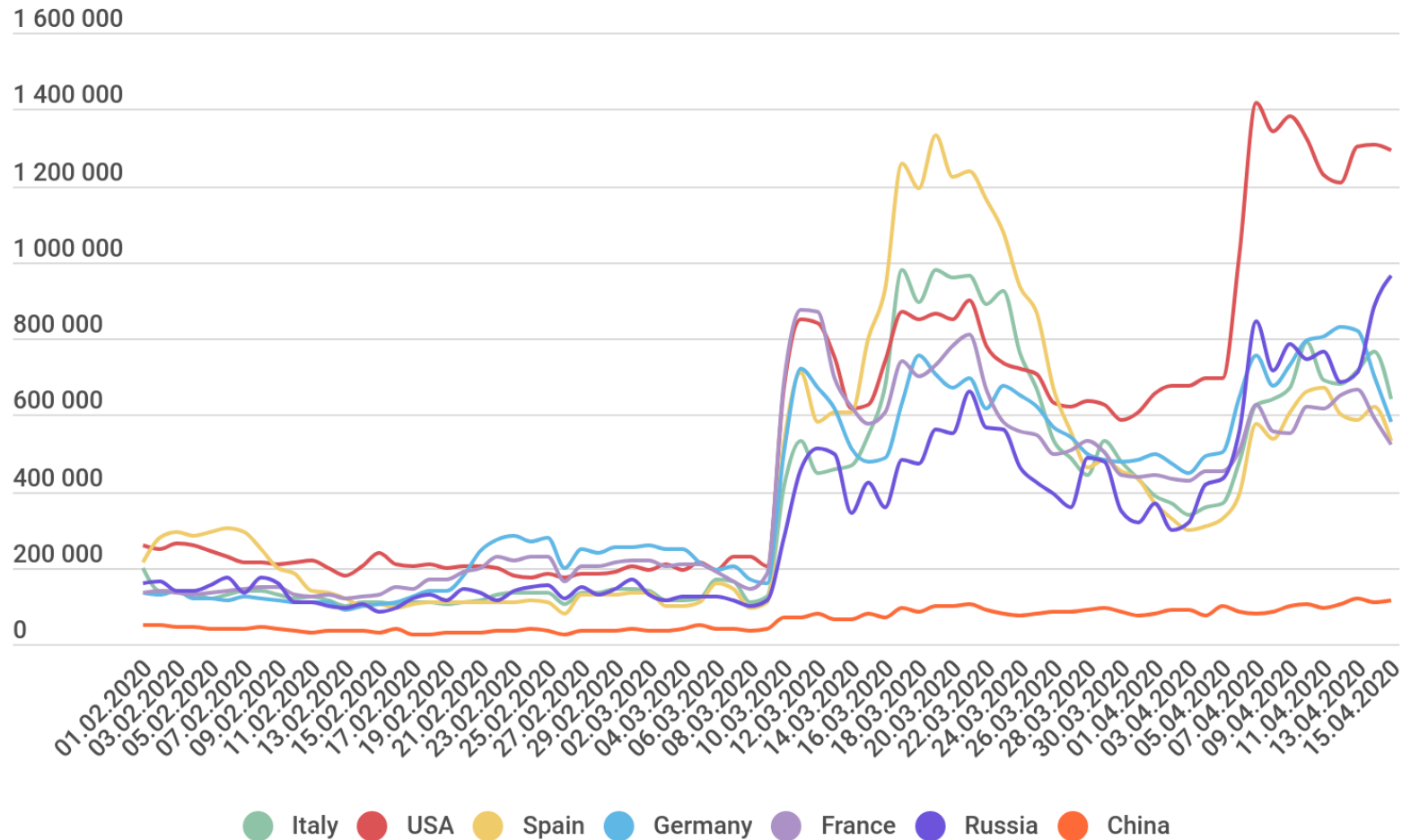
Desktop Remoto

Un altro approccio all'accesso remoto consiste nel consentire agli utenti di controllare in remoto un sistema che risiede già nella rete aziendale.

I sistemi utilizzati tramite desktop remoti possono essere fisici o virtuali. Inoltre, i sistemi virtuali possono essere persistenti o possono essere distrutti e ricreati frequentemente, talvolta esistenti solo per la durata della sessione di accesso di un utente. I sistemi desktop remoti che utilizzano la virtualizzazione sono talvolta chiamati infrastruttura desktop virtuale (VDI).

Come con le VPN, i desktop remoti richiedono l'accesso autenticato, ma praticano una forma di isolamento più estrema: il dispositivo endpoint non è un partecipante di prima classe nella rete aziendale; invece presenta all'utente una finestra in un altro sistema che lo è. Sebbene questo approccio aggiunga astrazione e difficoltà al lavoro di un utente malintenzionato che cerca di compromettere l'azienda, è ancora possibile osservare e persino manipolare i sistemi aziendali dall'altra parte della finestra.

Desktop Remoto – Attacchi noti

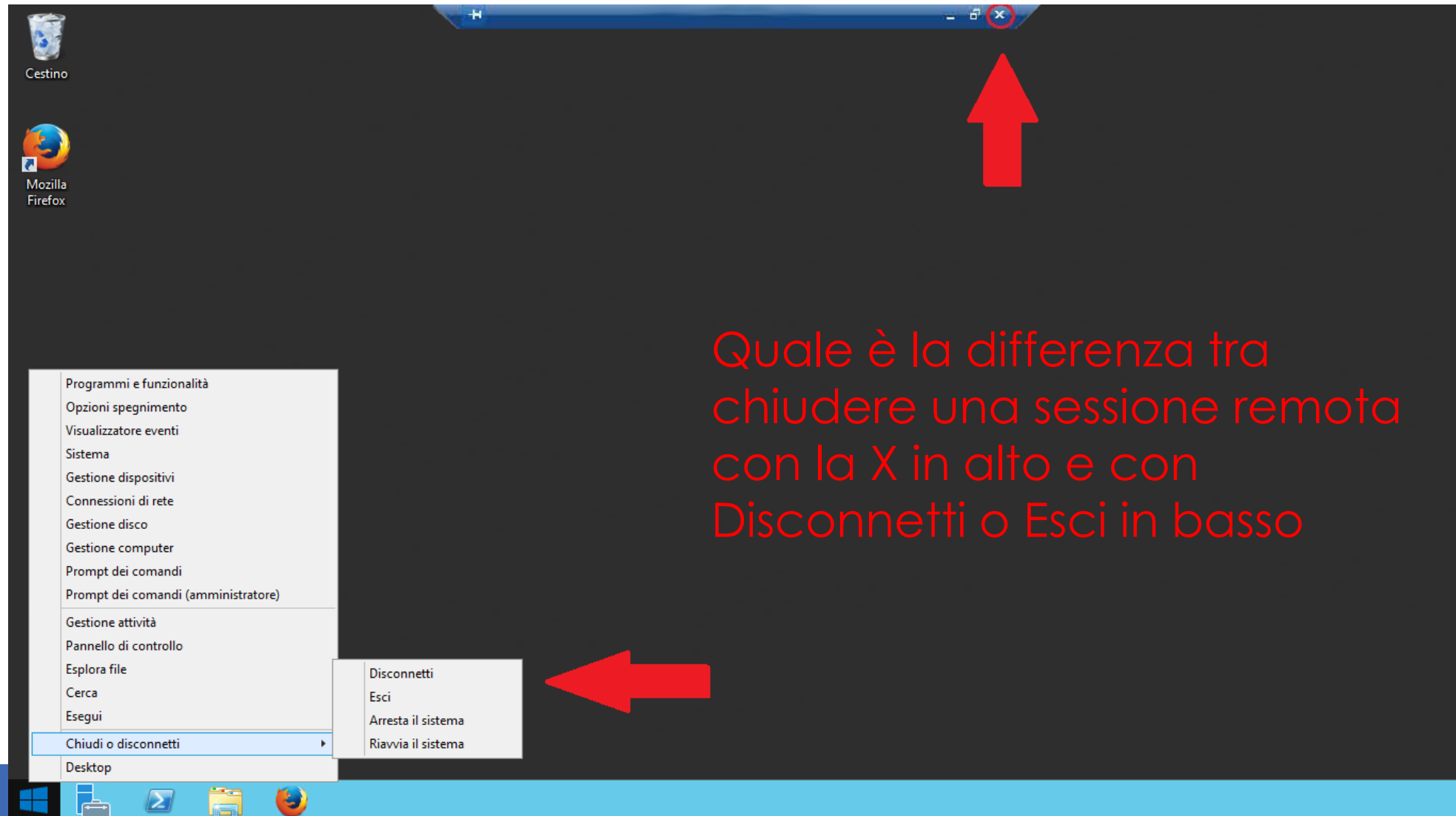


Desktop Remoto

In informatica il desktop remoto è un'implementazione del servizio di accesso remoto tramite interfaccia grafica anziché shell testuale, ovvero indica la capacità di un certo sistema di elaborazione di aprire una sessione utente di tipo grafico o comunque interattivo su un computer remoto, collegato in Rete, attraverso una connessione remota, utilizzando le risorse di input/output del computer locale.

La sessione remota è assolutamente indistinguibile da una sessione locale l'utente ha il pieno controllo dell'interfaccia grafica e dell'ambiente operativo (relativamente ai suoi privilegi di utente come definiti sulla macchina remota) e gli strumenti di input/output locali (schermo, tastiera, dispositivi di puntamento, stampanti) funzionano come se fossero collegati direttamente al computer remoto.

Piccole o Grandi differenze



Piccole o Grandi differenze

Molti di noi spesso chiudono una sessione remota utilizzando la famosa «X» in alto nella barra blu ma esiste una differenza nell'utilizzare la «X» il tasto funzione disconnetti o il tasto esci?

La risposta è assolutamente SI !!!

O meglio tra chiudere con la «X» e utilizzare disconnetti non sono esattamente la stessa cosa ma tra loro ed esci c'è una grande differenza

Piccole o Grandi differenze

La funzione che viene eseguita chiudendo con la «X» è esattamente la stessa di quella eseguita utilizzando disconnetti che in sostanza serve per chiudere la sessione in locale (nostro pc) ma lasciandola attiva nel computer remoto (server dove ci siamo connessi) interrompiamo semplicemente il collegamento tra noi e il server.

La funzione eseguita da esci invece chiude sia la sessione in locale che quella remota

Il primo caso dovrebbe essere scelto solo se ci sono delle attività che hanno bisogno di tempo per terminare (backup, copia di file, ecc.) ma una volta che sappiamo che sono terminate è buona prassi riconnetterci per chiudere correttamente la sessione con esci.

Piccole o Grandi differenze

Disconnettendo solo la sessione locale e non quella remota a quali rischi andiamo incontro?



Piccole o Grandi differenze

Se un hacker prende il controllo di un server perché ad esempio è riuscito a trovare la password di un utente e si connette in desktop remoto può eseguire delle azioni legate ai privilegi assegnati all'utenza utilizzata ma se altri utenti si sono collegati allo stesso server e hanno chiuso la sessione con disconnetti invece che con esci l'hacker ne può assumere il controllo aumentando magari anche i privilegi che queste utenze hanno rispetto alla precedente.

Sfruttando un comando di Microsoft che è TSCON che utilizzerà per dirottare la sessione rimasta aperta su quella utilizzata da lui prendendone il controllo senza conoscere la password.

Piccole o Grandi differenze

Ora vediamo una demo dove nella prima parte simuliamo un utente (signor Bianchi) che connesso in desktop remoto esegue la disconnessione alla sessione utilizzando la «X» mentre nella seconda parte simuliamo l'hacker che ha rubato le credenziali del signor Rossi che usa per connettersi in desktop remoto (allo stesso server del signor Bianchi) e diretta (prendendone il controllo) la sessione del signor Bianchi su quella del signor Rossi senza conoscere la password acquisendo i suoi privilegi che come vedremo sono decisamente maggiori.

Nella terza parte il signor Bianchi esegue la disconnessione con esci e confrontiamo ciò che l'hacker vede ora con prima.

Piccole o Grandi differenze

Come abbiamo visto nella demo da «semplice» amministratore locale l'hacker è riuscito ad ottenere privilegi da Domain Admin con i quali può controllare e quindi modificare l'intero dominio.

La funzione disconnetti o il tasto «X» devono essere usare solo in alcuni casi specifici e se utilizzate non con utenze con alti privilegi e terminate le attività ricordarsi di eseguire correttamente la disconnessione sia locale che remota utilizzando la funzione esci.

Desktop Remoto – Mitigazioni

- Utilizzare i criteri di gruppo per specificare gli elenchi di autorizzazioni e gli elenchi di blocco delle applicazioni.
- Disabilitare le schede delle impostazioni in Internet Explorer (puoi farlo localmente tramite il registro)
- Utilizzare lo strumento Regedit per impedire l'apertura della funzionalità della Guida di Windows incorporata (che causa l'apertura di Internet Explorer e potenziale accesso ai file)
- Disabilitare l'opzione di montaggio di unità locali per le connessioni remote, se non è fondamentale per la propria organizzazione.
- Limitare l'accesso alle unità locali di una macchina remota, mantenendo accessibili solo le cartelle utente.
- Rimuovere i privilegi di amministratore e applicare il **principio del minimo privilegio**, ad esempio con una soluzione di gestione degli accessi privilegiati (PAM), che può consentire un'efficace amministrazione di Windows senza Domain Admin o altri privilegi di superutente.

Tenere a mente che Microsoft non è l'unico ambiente che soffre di tali attacchi. Le reti macOS di Apple hanno visto un drammatico aumento degli attacchi ransomware relativi ai desktop remoti.

Accesso Remoto – Attacchi noti

L'attacco ransomware al Comune di Torino è un esempio di come l'accesso remoto non gestito opportunamente può avere effetti deleteri.

La causa è stata attribuita ad una macchina presso i vigili urbani, non gestita direttamente dal Comune, ma che comunque dialogava con la rete interna e scambiava informazioni.

E' stato il punto di ingresso degli hacker russi del network «Conti» che hanno causato una quantità di disagi che si sono risolti dopo diversi giorni.

Dispositivi personali

Tradizionalmente si accedeva alle reti aziendali solo su apparecchiature fornite dall'azienda. Questa disposizione ha consentito alle aziende un accesso illimitato per monitorare e configurare il dispositivo con precisione in base ai loro profili di rischio e strategie di mitigazione. Ha inoltre richiesto all'impresa di acquistare e mantenere le attrezzature.

L'alternativa è consentire l'accesso alle risorse aziendali su dispositivi posseduti dall'utente, il cosiddetto modello BYOD (Bring Your Own Device). Il BYOD può rappresentare un notevole risparmio sui costi per l'azienda rispetto all'emissione di dispositivi di proprietà dell'azienda e gli utenti sono spesso più felici perché possono utilizzare dispositivi familiari per svolgere il proprio lavoro.

Inoltre, un dispositivo che l'utente ha già può essere utilizzato immediatamente, senza dover procurare e spedire il dispositivo all'utente. Per molte organizzazioni, il modello BYOD è stato essenziale per la velocità e l'efficacia del loro passaggio al lavoro remoto.

Con tutti questi vantaggi deriva un rischio significativo: una ridotta capacità di controllare la configurazione del dispositivo fornito dall'utente.

Dispositivi personali – Attacco Regione Lazio

L'attacco Ransomware alla Regione Lazio pare sia partito dall'utenza in VPN (Virtual Private Network) di un dipendente della Regione localizzato a Frosinone, dove lo stesso operava da remoto in regime di smart working e da dove si è appurata, inoltre, l'assenza di una procedura di sicurezza standard di accesso al sistema informatico regionale tramite "autenticazione a più fattori".

I cybercriminali, verosimilmente tramite un Trojan (che tipicamente si diffonde via mail al malcapitato sotto forma di allegato e che viene da lui aperto quasi in maniera "inconsapevole"), inizialmente hanno avuto accesso all'utenza del dipendente regionale dove hanno installato comodamente una backdoor.

Da qui sono poi penetrati nell'intero sistema, fino ad un'utenza con privilegi di amministratore da cui hanno sferrato l'attacco.

Dispositivi personali - Mitigazioni

E' emerso un ecosistema di soluzioni di gestione degli endpoint per soddisfare questa esigenza.

Questo ecosistema viene spesso definito soluzioni di gestione unificata degli endpoint (**UEM**) poiché è cresciuto fino a includere laptop e altri dispositivi oltre a telefoni e tablet.

Un componente di una soluzione UEM è un'applicazione sul dispositivo dell'utente finale che monitora le informazioni di interesse per l'azienda, come il software installato e le versioni. Il software UEM può anche imporre alcune opzioni di configurazione, come la configurazione di un firewall potente o l'uso di un proxy aziendale per la navigazione web.

Le applicazioni del dispositivo dell'utente finale di solito comunicano con processi lato server che verificano che le configurazioni del dispositivo siano appropriate per l'accesso aziendale e distribuiscono la configurazione o gli aggiornamenti software.

Furto di credenziali

Il furto di credenziali implica l'ottenimento illecito della password di un'organizzazione o di un individuo con l'intento di accedere e abusare/esfiltrare dati e informazioni critici.

Spesso eseguito nella fase iniziale di un attacco informatico, il furto di credenziali consente agli aggressori di operare senza essere scoperti in una rete, reimpostare le password e provocare il caos all'interno di un'organizzazione.

Le tecniche principali per eseguire un attacco mirato al furto di credenziali sono:

- Phishing
- Malware (ad esempio Keyloggers)
- Attacchi brute-force
- Credential stuffing

Altre cause del furto di credenziali sono da riportare alle vulnerabilità di applicazioni e robustezza delle password.

Furto di credenziali - Phishing

A causa della mancata adozione dell'autenticazione a più fattori e delle best practices di robustezza per le password, il numero di furti di credenziali tramite phishing è cresciuto in modo esponenziale. Inoltre è utilizzato anche per la consegna di malware.

- **Spear phishing** implica l'obiettivo di organizzazioni o individui specifici per rubare informazioni sensibili come le credenziali dell'account. In questo tipo di attacco, gli hacker si travestono da identità affidabili e in genere accedono a informazioni sensibili tramite e-mail spoofing o infiltrandosi in altri sistemi di messaggistica online.
- **Whaling** è un tipo di attacco di spear phishing rivolto ai dirigenti di alto livello all'interno di un'organizzazione e spesso impersonano i reclami dei clienti o i problemi personali.
- **Clone phishing:** viene effettuato rubando un'e-mail precedentemente consegnata contenente un allegato e/o un collegamento e quindi utilizzandola per creare un'e-mail simile o "clonata" con l'intento di ottenere l'accesso a credenziali privilegiate. Di solito gli allegati/collegamenti vengono sostituiti con versioni dannose e l'indirizzo e-mail viene leggermente modificato per ingannare il destinatario.

Phishing- Attacco SIAE

L'attacco portato alla SIAE con conseguente data exfiltration è cominciato proprio grazie allo Spear phishing.

L'attacco di è tradotto nel furto di 28.000 file contenenti carte d'identità, codici fiscali, brani musicali quasi tutti inediti depositati e altre informazioni.

Gli attaccanti hanno cominciato a mandare degli sms e dei whatsapp ad alcuni associati chiedendo loro di rispondere per evitare di essere cancellati dalla Siae.

Questo ha ovviamente causato una raccolta di informazioni utili per accedere ai sistemi della SIAE.

Si è stimata una quantità di dati rubati che si aggira sui 60GB.

Furto di credenziali - Mitigazioni

- Fornire la consapevolezza sulle problematiche di sicurezza ai dipendenti dell'organizzazione o agli utenti dei proprio sistemi
- Eseguire verifiche di sicurezza su sistemi e applicazioni
- Adottare misure a livello di applicazioni e di sistema per mitigare attacchi di credential-stuffing e brute-force (policy di validazione/blocco dell'account, Web Application Firewall)
- Utilizzare IDS e IPS
- Ispezione regolare dei log per individuare eventuali anomalie nelle attività delle utenze causate dal furto di credenziali (e magari successiva elevazione di privilegio)

Cybersecurity

Minacce e scenari d'attacco

Modulo III

- Il modello Zero Trust -

Il modello Zero Trust

Zero Trust è un framework per la protezione dell'infrastruttura e dei dati per la moderna trasformazione digitale. Affronta in modo univoco le sfide moderne del business di oggi, inclusa la protezione dei lavoratori remoti, gli ambienti cloud ibridi e le minacce ransomware.

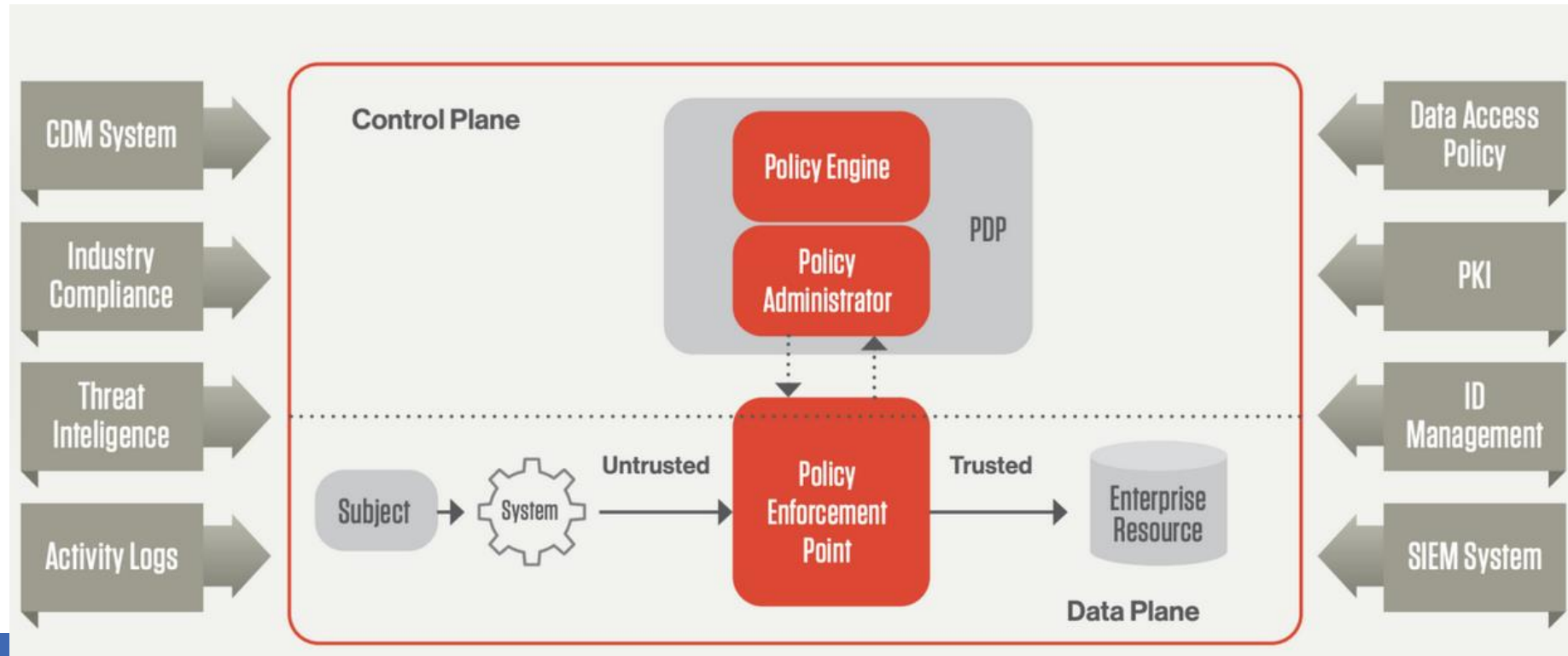
Zero Trust richiede a tutti gli utenti, sia all'interno che all'esterno della rete dell'organizzazione, di essere autenticati, autorizzati e continuamente convalidati per la configurazione e la posizione della sicurezza prima di concedere o mantenere l'accesso ad applicazioni e dati.

Zero Trust presuppone che non ci sia un perimetro di rete tradizionale; le reti possono essere locali, nel cloud, combinate o ibride con risorse ovunque e lavoratori in qualsiasi luogo.

Il modello Zero Trust

NIST 800-207 (1)

Il NIST ha fornito le linee guida per l'implementazione e l'adozione di un architettura Zero Trust



Il modello Zero Trust

NIST 800-207 (2)

Zero Trust cerca di affrontare i seguenti principi chiave basati sulle linee guida del NIST:

1. **Verifica continua.** Verifica sempre l'accesso, sempre, per tutte le risorse.
2. **Limitare il "raggio di esplosione".** Ridurre al minimo l'impatto se si verifica una violazione esterna o interna.
3. **Automatizza la raccolta e la risposta del contesto.** Incorpora i dati comportamentali e ottieni il contesto dall'intero stack IT (identità, endpoint, carico di lavoro, ecc.) per la risposta più accurata.

Il modello Zero Trust

L'architettura Zero Trust richiede quindi alle organizzazioni di **monitorare e convalidare** continuamente che un utente e il suo dispositivo dispongano dei privilegi e degli attributi corretti.

Richiede inoltre l'applicazione di policy che includano il rischio dell'utente e del dispositivo, insieme alla conformità o ad altri requisiti da considerare prima di consentire la transazione.

Richiede che l'organizzazione conosca **tutti i servizi e gli account privilegiati** e possa stabilire controlli su cosa e dove si connettono. La convalida una tantum semplicemente non sarà sufficiente, perché le minacce e gli attributi degli utenti sono tutti soggetti a modifiche.

Il modello Zero Trust

Le organizzazioni devono garantire che tutte le richieste di accesso siano continuamente controllate prima di consentire l'accesso a qualsiasi risorsa aziendale o cloud. Ecco perché l'applicazione delle policy Zero Trust si basa sulla visibilità in tempo reale di centinaia di attributi di identità di utenti e applicazioni come:

- Identità utente e tipo di credenziale (umana, programmatica)
- Numero e privilegi di ogni credenziale su ogni dispositivo
- Connessioni normali per le credenziali e il dispositivo (modelli di comportamento)
- Tipo e funzione dell'hardware dell'endpoint
- Posizione geografica
- Versioni firmware
- Protocollo di autenticazione e rischio
- Versioni del sistema operativo e livelli di patch
- Applicazioni installate sull'endpoint
- Rilevamenti di sicurezza o incidenti, tra cui attività sospette e riconoscimento di attacchi

Il modello Zero Trust – Principi di base

Tutte le origini dati e i servizi informatici sono considerati risorse.

Una rete può essere composta da più classi di dispositivi.

Una rete può anche avere dispositivi di piccole dimensioni che inviano dati ad aggregatori e sistemi di archiviazione, software come servizio (SaaS), sistemi che inviano istruzioni e altre funzioni.

Inoltre, un'azienda può decidere di classificare i dispositivi di proprietà personale come risorse se possono accedere alle risorse di proprietà dell'azienda.

Il modello Zero Trust – Principi di base

Tutte le comunicazioni sono protette indipendentemente dalla posizione della rete.

La posizione di rete da sola non implica fiducia.

Le richieste di accesso da risorse situate su un'infrastruttura di rete di proprietà dell'azienda (ad esempio, all'interno di un perimetro di rete legacy) devono soddisfare gli stessi requisiti di sicurezza delle richieste di accesso e comunicazione da qualsiasi altra rete non di proprietà dell'azienda.

In altre parole, la fiducia non dovrebbe essere concessa automaticamente in base al dispositivo che si trova sull'infrastruttura di rete aziendale.

Tutte le comunicazioni devono

- essere effettuate nel modo più sicuro disponibile
- proteggere la riservatezza e l'integrità
- fornire l'autenticazione della fonte.

Il modello Zero Trust – Principi di base

L'accesso alle singole risorse aziendali è basato su sessione.

La fiducia nel richiedente viene valutata prima di concedere l'accesso.

L'accesso dovrebbe essere concesso, inoltre, con i privilegi minimi necessari per completare l'attività.

Ciò potrebbe significare solo "qualche volta di recente" per questa particolare transazione e potrebbe non verificarsi direttamente prima di avviare una sessione o eseguendo una transazione con una risorsa.

Tuttavia, l'autenticazione e l'autorizzazione verso una risorsa non concederanno automaticamente l'accesso verso una risorsa diversa.

Il modello Zero Trust – Principi di base

L'accesso alle risorse è determinato da policy dinamiche, incluso lo stato osservabile dell'identità del client, dell'applicazione/servizio e dell'asset richiedente, e può includere altri attributi comportamentali e ambientali.

Per zero trust, l'identità del client può includere l'account utente (o l'identità del servizio) e qualsiasi attributo associato assegnato dall'azienda a tale account o artefatti per l'autenticazione automatizzata.

La richiesta dello stato dell'asset può includere le caratteristiche del dispositivo come le versioni del software installate, il percorso di rete, l'ora/data della richiesta, il comportamento osservato in precedenza e le credenziali installate.

Gli attributi comportamentali includono, a titolo esemplificativo, analisi automatizzate dei soggetti, analisi dei dispositivi e deviazioni misurate dai modelli di utilizzo osservati.

La policy è l'insieme di regole di accesso basate sugli attributi che un'organizzazione assegna a un soggetto, una risorsa dati o un'applicazione. Gli attributi ambientali possono includere fattori quali l'ubicazione della rete del richiedente, l'ora, gli attacchi attivi segnalati e così via. Queste regole e attributi si basano sulle esigenze del processo aziendale e sul livello di rischio accettabile. I criteri di accesso alle risorse e di autorizzazione all'azione possono variare in base alla sensibilità della risorsa/dei dati. I principi di privilegio minimo vengono applicati per limitare sia la visibilità che l'accessibilità.

Il modello Zero Trust – Principi di base

L'azienda monitora e misura l'integrità e la posizione di sicurezza di tutte le risorse di proprietà e associate.

Nessuna risorsa è intrinsecamente affidabile. L'impresa valuta la posizione di sicurezza dell'asset durante la valutazione di una richiesta di risorse.

Un'azienda che implementa una ZTA dovrebbe stabilire una diagnostica continua e un sistema di mitigazione (CDM) o un sistema simile per monitorare lo stato di dispositivi e applicazioni e dovrebbe applicare patch/correzioni secondo necessità. Le risorse scoperte come sovvertite, che presentano vulnerabilità note e/o non sono gestite dall'impresa possono essere trattate in modo diverso (inclusa la negazione di tutte le connessioni alle risorse aziendali) rispetto ai dispositivi posseduti o associati all'impresa che si ritiene nel loro stato più sicuro.

Ciò può valere anche per i dispositivi associati (ad es. dispositivi di proprietà personale) a cui può essere consentito l'accesso ad alcune risorse ma non ad altre. Anche questo richiede un solido sistema di monitoraggio e reporting in atto per fornire dati fruibili sullo stato attuale delle risorse aziendali

Il modello Zero Trust – Principi di base

L'autenticazione e l'autorizzazione di tutte le risorse sono dinamiche e applicate rigorosamente prima che l'accesso sia consentito.

Questo è un ciclo costante di ottenimento dell'accesso, scansione e valutazione delle minacce, adattamento e rivalutazione continua della fiducia nella comunicazione in corso.

Ci si aspetterebbe che un'impresa che implementa una ZTA disponga di Identity, Credential e Access Management (ICAM) e sistemi di asset management. Ciò include l'uso dell'autenticazione a più fattori (MFA) per l'accesso ad alcune o tutte le risorse aziendali.

Il monitoraggio continuo con possibile riautenticazione e riautorizzazione avviene durante le transazioni degli utenti, come definito e imposto dalla policy (ad es. risorsa richiesta, modifica della risorsa, attività anomala del soggetto rilevata) che si sforza di raggiungere un equilibrio tra sicurezza, disponibilità, usabilità ed efficienza dei costi.

Il modello Zero Trust – Principi di base

L'azienda raccoglie quante più informazioni possibili sullo stato attuale delle risorse, dell'infrastruttura di rete e delle comunicazioni e le utilizza per migliorare la propria posizione di sicurezza.

Un'azienda dovrebbe raccogliere dati sullo stato di sicurezza delle risorse, sul traffico di rete e sulle richieste di accesso, elaborare tali dati e utilizzare qualsiasi conoscenza acquisita per migliorare la creazione e l'applicazione delle policy.

Tali dati possono essere utilizzati anche per contestualizzare richieste di accesso da parte di soggetti.

Cybersecurity

Minacce e scenari d'attacco

Modulo IV

- Storie di data breach -

Violazione dei dati

Un data breach o "fuga di dati" è la diffusione intenzionale o non intenzionale, in un ambiente non affidabile, di informazioni protette o private/confidenziali.

Un'altra espressione inglese utilizzata in proposito è information leakage.

Incidenti di questo tipo sono causati da:

- attacchi concertati black hat
- individui che svolgono attacchi informatici per qualche forma di lucro personale, associati con criminalità organizzata
- attivisti politici o governi nazionali
- imprudente abbandono di apparecchi informatici o supporti di memoria

Violazione dei dati

Nei data breach a seconda del sito compromesso possiamo trovare uno o più dei seguenti dati che se presi singolarmente a volte non provocano danni ma se sommati tra loro (dati di vari data breach) la questione cambia.

Nome e Cognome	Carte di credito
Username	Numero di telefono
Indirizzo di domicilio	Email
Patente / Passaporto	Lavoro

Storie di data breach

Personaggio di fantasia ambientato in data breach reali

Un giovane ragazzo di nome Luca di nazionalità indiana come i suoi coetanei ama la tecnologia e utilizza il proprio computer/cellulare per giocare, fare acquisti su siti di e-commerce, prenotare voli aerei, iscriversi sui social e perché nò anche ordinare del cibo a casa.

Fino qui nulla di strano anche perché molti di noi ormai siamo abituati a compiere tali azioni solo ché sta' succedendo qualcosa all'insaputa di Luca ovvero i suoi dati non sono più segreti e custoditi nei siti dove lui li ha volontariamente inseriti ma qualcuno al di fuori ha iniziato a "conoscerlo meglio".

Storie di data breach

Personaggio di fantasia ambientato in data breach reali

1 Agosto 2019

Storie di data breach

Personaggio di fantasia ambientato in data breach reali



Facebook

In April 2021, a large data set of over 500 million Facebook users was made freely available for download. Encompassing approximately 20% of Facebook's subscribers, the data was allegedly obtained by exploiting a vulnerability Facebook advises they rectified in August 2019. The primary value of the data is the association of phone numbers to identities; whilst each record included phone, only 2.5 million contained an email address. Most records contained names and genders with many also including dates of birth, location, relationship status and employer.

Breach date: 1 August 2019

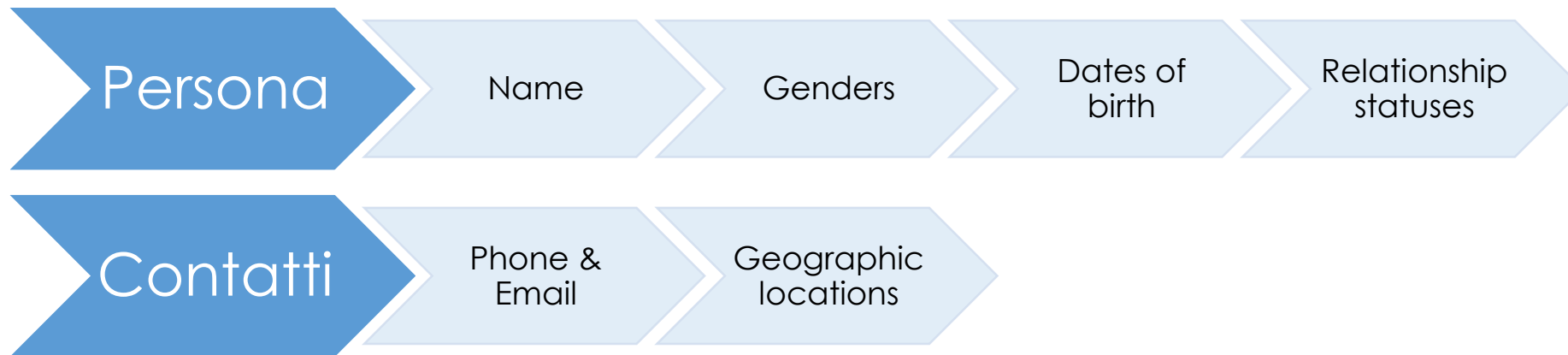
Compromised accounts: 509,458,528

Compromised data: Dates of birth, Email addresses, Genders, Geographic locations, Names, Phone numbers, Relationship statuses

Storie di data breach

Personaggio di fantasia ambientato in data breach reali

Ora gli hacker hanno in mano alcune informazioni di Luca che sono:



Storie di data breach

Personaggio di fantasia ambientato in data breach reali

24 Marzo 2021

Storie di data breach

Personaggio di fantasia ambientato in data breach reali



Domino's India

In April 2021, 13TB of compromised Domino's India appeared for sale on a hacking forum after which the company acknowledged a major data breach they dated back to March. The compromised data included 22.5 million unique email addresses, names, phone numbers, order histories and physical addresses.

Breach date: 24 March 2021

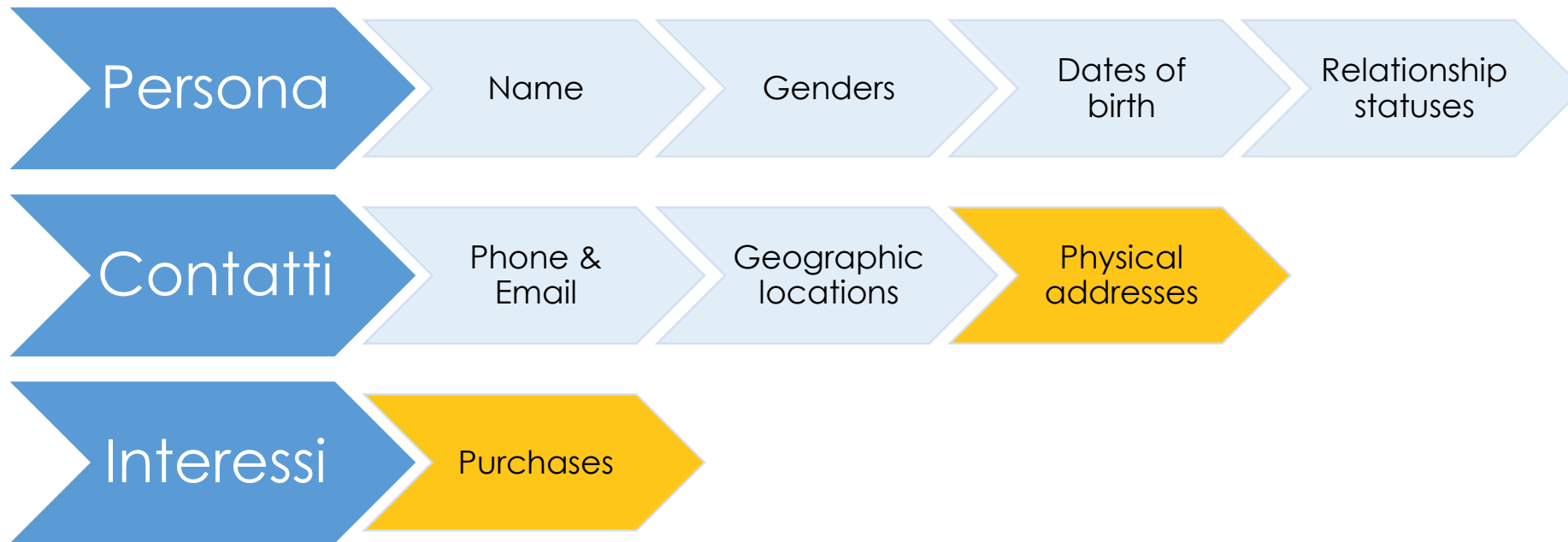
Compromised accounts: 22,527,655

Compromised data: Email addresses, Names, Phone numbers, Physical addresses, Purchases

Storie di data breach

Personaggio di fantasia ambientato in data breach reali

Nuove informazioni di Luca che sono state trovate sono:



* In giallo i nuovi dati acquisiti

Storie di data breach

Personaggio di fantasia ambientato in data breach reali

08 Aprile 2021

Storie di data breach

Personaggio di fantasia ambientato in data breach reali



LinkedIn Scraped Data

During the first half of 2021, LinkedIn was targeted by attackers who scraped data from hundreds of millions of public profiles and later sold them online. Whilst the scraping did not constitute a data breach nor did it access any personal data not intended to be publicly accessible, the data was still monetised and later broadly circulated in hacking circles. The scraped data contains approximately 400M records with 125M unique email addresses, as well as names, geographic locations, genders and job titles. LinkedIn specifically addresses the incident in their post on [An update on report of scraped data](#).

Breach date: 8 April 2021

Compromised accounts: 125,698,496

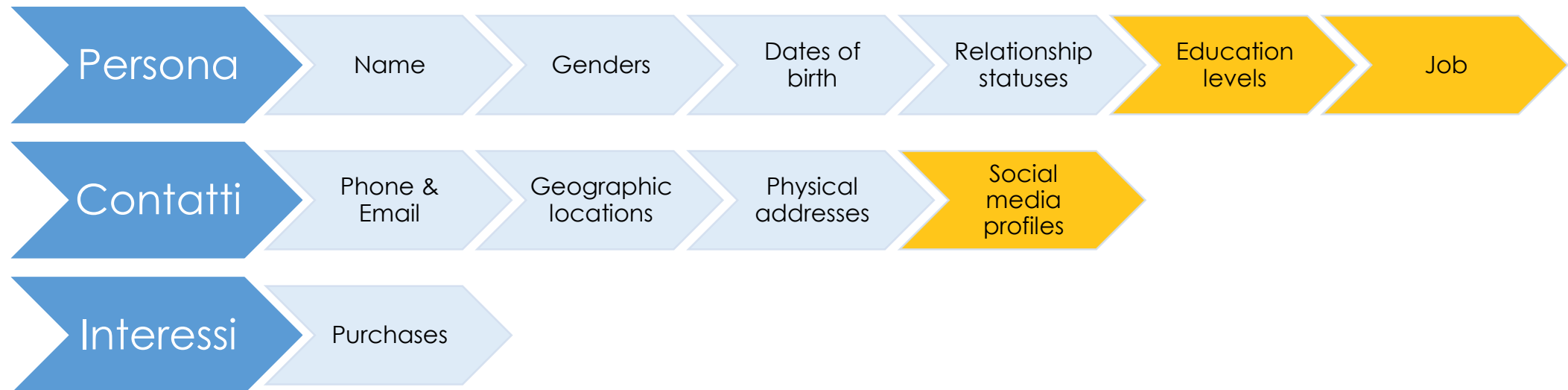
Compromised data: Education levels, Email addresses, Genders, Geographic locations, Job titles, Names, Social media profiles

[1] <https://haveibeenpwned.com/PwnedWebsites#LinkedInScrape>

Storie di data breach

Personaggio di fantasia ambientato in data breach reali

Nuove informazioni di Luca che sono state trovate sono:



* In giallo i nuovi dati acquisiti

Storie di data breach

Personaggio di fantasia ambientato in data breach reali

25 Febbraio 2021

Storie di data breach

Personaggio di fantasia ambientato in data breach reali



Air India

Air India inform that SITA PSS our data processor of the passenger service system (which is responsible for storing and processing of personal information of the passengers) had recently been subjected to a cybersecurity attack. This incident affected around 4,500,000 data subjects in the world. While we had received the first notification in this regard from our data processor on 25.02.2021, we would like to clarify that the identity of the affected data subjects was only provided to us by our data processor on 25.03.2021 & 5.04.2021. The breach involved personal data registered between 26th August 2011 and 3rd February 2021, with details that included name, date of birth, contact information, passport information, ticket information, Star Alliance, Air India frequent flyer data.

Breach date: 25 February 2021

Compromised accounts: 4,500,000

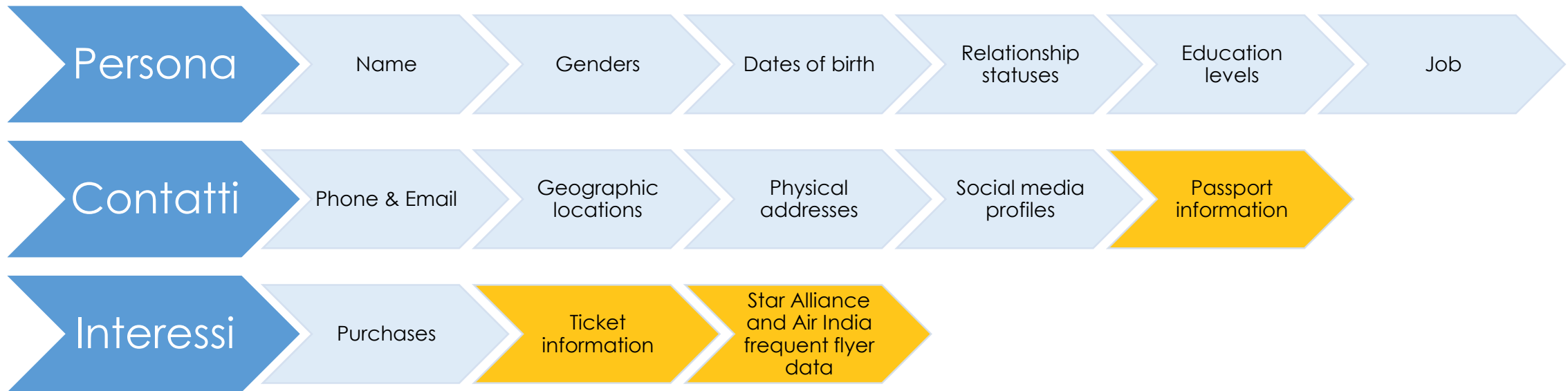
Compromised data: name, date of birth, contact information, passport information, ticket information, Star Alliance and Air India frequent flyer data

[1] <https://www.airindia.in/images/pdf/Data-Breach-Notification.pdf>

Storie di data breach

Personaggio di fantasia ambientato in data breach reali

Nuove informazioni di Luca che sono state trovate sono:

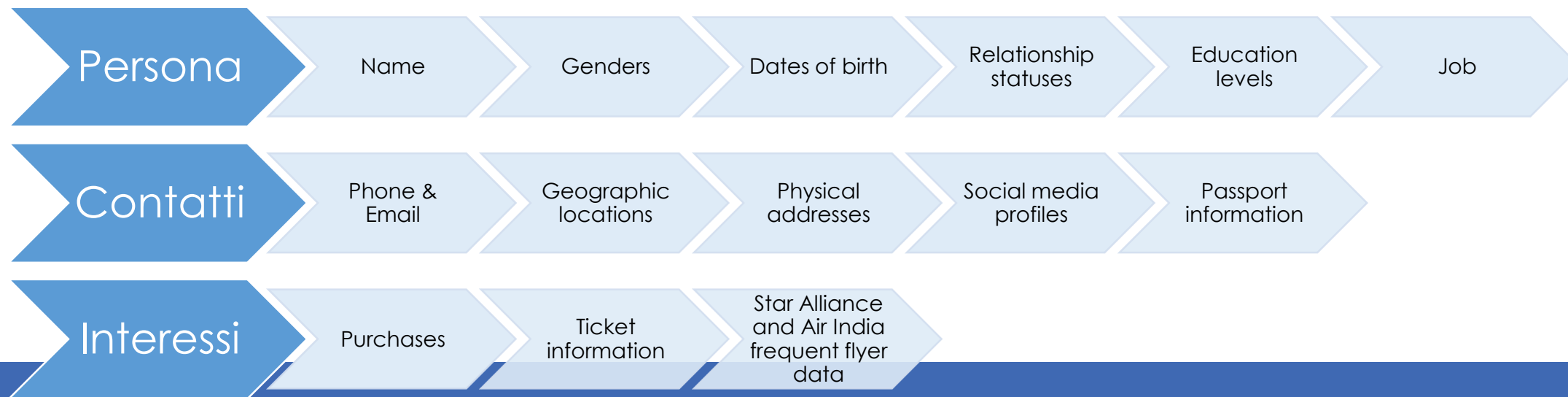


* In giallo i nuovi dati acquisiti

Storie di data breach

Personaggio di fantasia ambientato in data breach reali

Come possiamo vedere un'eventuale hacker ha praticamente tutte le informazioni di Luca anche se lui ne è all'oscuro...



Cybersecurity

Minacce e scenari d'attacco

Modulo IV

Difesa dell'infrastruttura utilizzando ATT&CK

Mitre ATT&CK Framework

ATT&CK

Una knowledge base sul comportamento avversario

- Basato su osservazioni del mondo reale
- Gratuito, aperto e accessibile a livello globale
- Un linguaggio comune
- Guidato dalla comunità

Tecniche: come vengono raggiunti gli obiettivi

Tecniche: come vengono raggiunti gli obiettivi

Tecniche: come vengono raggiunti gli obiettivi

Mitre ATT&CK Framework

Utilizziamo la conoscenza dei comportamenti dell'avversario per informare i difensori.

La funzionalità Navigator permette di selezionare insieme di tattiche in base a funzioni di ricerca e di studiare il comportamento avversario per implementare le giuste contromisure.

<https://mitre-attack.github.io/attack-navigator/>

GRAZIE